Concepts de routage et commutation

Chapitre 1

Cours de M. Petein Thomas

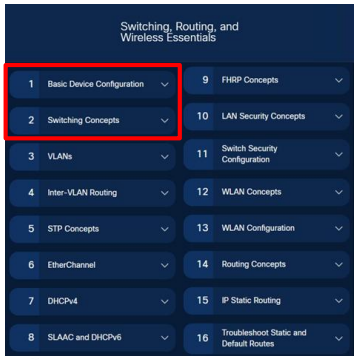
Email : thomas.petein@heh.be

Chapitre 1

UE - Télécommunications et réseaux – Routing & Switching

Voici l'ensemble des chapitres que nous allons essayer de voir à travers les différentes AA de l'UE Télécommunications et réseaux.

Télécommunications et réseaux - Routing & Switching (9ects)
- Concepts de routage et commutation - théorie
- Concepts de routage et commutation - travaux pratiques
- Télécommunications et réseaux avancés - théorie
- Télécommunications et réseaux avancés - travaux pratiques





Chapitre 1

But du chapitre

Ce premier chapitre est divisé en différentes parties :

Tout d'abord on va revoir les configurations de base concernant les commutateurs. On va également aborder la sécurisation de ces ports.

Ensuite on va parler du concept de commutation et de transfert des trames.

Après on parlera des réseaux actuels et de leur structure hiérarchique.

Finalement on abordera des notions complémentaires tel que le hachage, le chiffrement,…

Chapitre 1

Avant de configurer…

Avant de pouvoir configurer un commutateur, il va falloir l'allumer !

Et une fois allumé, il va falloir attendre qu'il démarre...

On va donc analyser ce qui se passe pendant ce démarrage.

Etape 1 :
Le commutateur exécute un programme de Power-On Self Test (POST) stocké dans la mémoire ROM. Le POST contrôle le sous-système du processeur. Il teste le processeur, la mémoire vive dynamique et la partie du périphérique flash qui compose le système de fichiers flash.

Etape 2 :
Il exécute le bootloader. Le bootloader est un petit programme stocké dans la mémoire morte et est exécuté immédiatement après la réussite du POST.

Etape 3 :
Il effectue l'initialisation de bas niveau du processeur, c-à-d les registres du processeur, la quantité de mémoire et sa vitesse.

Etape 4 :
Le bootloader initialise le système de fichiers flash sur la carte système.

Etape 5 :
Dernière étape, il localise et charge une image de logiciel du système d'exploitation IOS par défaut dans la mémoire et transfère le contrôle du commutateur à l'IOS.

Le démarrage étant terminé et l'IOS chargé, c'est lui qui initialise les interfaces à l'aide des commandes Cisco IOS figurant dans le fichier de configuration, startup-config, qui est stocké dans la mémoire NVRAM.

Il faut savoir également que le commutateur tente de démarrer automatiquement en utilisant les informations de la variable d'environnement BOOT.

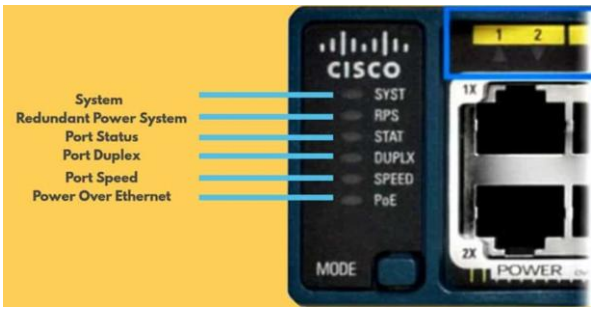
Cette variable d'environnement BOOT est définie à l'aide de la commande de mode de configuration globale **boot system**.

S1(config)# **boot system flash:/c2960-lanbasek9-mz.150-2.SE/c2960-lanbasek9-mz.150-2.SE.bin**

commande — périphérique de stockage — chemin d'accès — le nom du fichier IOS

Les indicateurs LED

Les commutateurs Cisco Catalyst ont plusieurs témoins lumineux LED. Vous pouvez utiliser les LED du commutateur pour surveiller rapidement l'activité et les performances du commutateur.



• **LED système (SYST) :** indique si le système est bien alimenté et s'il fonctionne correctement.

LED éteinte = système hors tension.
LED verte = système fonctionne normalement.
LED orange = système sous tension mais ne fonctionne pas correctement.

• **LED système d'alimentation redondante (RPS) :** affiche l'état du système RPS.
LED éteinte = système RPS éteint ou pas correctement connecté.

LED verte = système RPS connecté et prêt à fournir l'alimentation de secours.
LED verte et clignote = système RPS connecté mais n'est pas disponible parce qu'il alimente un autre périphérique.
LED orange = le système RPS est en veille ou en erreur.
LED orange et clignote = l'alimentation interne du commutateur a rencontré une erreur et le système RPS a pris le relais de l'alimentation.

Chapitre 1

• **LED état port (STAT) :** indique que le mode état de port est sélectionné lorsque la LED est verte et clignote. En mode par défaut, les LED du port affichent des couleurs de différentes significations.

LED éteinte = aucune liaison n'est établie ou le port a été arrêté administrativement.
LED verte = liaison établie.
LED verte et clignote = liaison active + envoi ou réception de données.
LED orange = le port est bloqué pour éviter tout bouclage.

• **LED de bidirectionnalité du port (DUPLX) :** indique que le mode de bidirectionnalité du port est sélectionné lorsque la LED est verte. Lorsque ce mode est sélectionné, les LED éteintes indiquent les ports en mode bidirectionnel non simultané.

• **LED de vitesse de port (SPEED) :** indique que le mode vitesse de port est sélectionné.

LED éteinte = le port fonctionne à 10 Mbit/s.
LED verte = le port fonctionne à 100 Mbit/s.
LED verte et clignote = le port fonctionne à 1 000 Mbit/s.

• **LED de mode Power over Ethernet (PoE) :** si le mode POE est pris en charge, une LED de mode PoE est présente.

LED éteinte = le mode PoE n'est pas sélectionné et aucun port n'est privé de courant ou ne présente d'erreur.
LED orange et clignote = le mode PoE n'est pas sélectionné mais au moins un port est privé de courant ou présente une erreur relative au PoE.

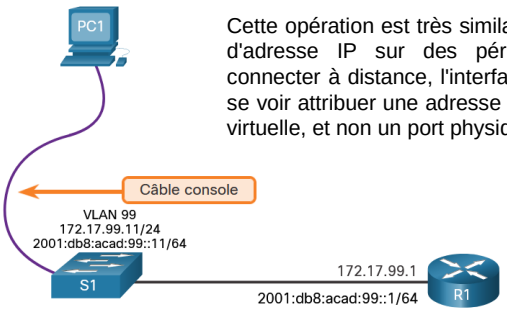
LED verte = le mode PoE est sélectionné et les LED de port présentent différentes couleurs, dont la signification varie.

- LED de port éteinte = le mode PoE est désactivé.
- LED de port verte, le mode PoE est activé.
- LED de port alterne entre vert et orange = le mode PoE est refusé car l'alimentation du périphérique entraînerait un dépassement de la capacité électrique du commutateur.
- LED orange = le mode PoE est désactivé pour le port.

Gestion à distance

Pour préparer l'accès à la gestion à distance d'un commutateur, il est nécessaire de configurer une adresse IP et un masque de sous-réseau sur le commutateur.

Gardez à l'esprit que pour administrer le commutateur depuis un réseau distant, le commutateur doit être configuré avec une passerelle par défaut.



Cette opération est très similaire à la configuration des informations d'adresse IP sur des périphériques hôtes. Pour pouvoir se connecter à distance, l'interface virtuelle du commutateur (SVI) doit se voir attribuer une adresse IP. Une interface SVI est une interface virtuelle, et non un port physique du commutateur.

Comme vous le savez, par défaut, le commutateur est configuré de telle sorte que sa gestion est régie par le VLAN 1. Tous les ports sont donc assignés à VLAN 1 par défaut.

Pour des raisons de sécurité évidentes, on recommande d'utiliser un VLAN de gestion autre que le VLAN 1.

Procédure à suivre :

Etape 1 : Si l'on souhaite administrer le commutateur à partir d'un VLAN de gestion différent du VLAN 1 (comme par exemple le VLAN 99), il faut tout d'abord créer celui-ci et lui associer les ports désirés.

S1(config)# **vlan** *99*
S1(config-vlan)# **name** *Gestion*
S1(config-vlan)# **exit**
S1(config)# **interface** *vlan 99*
S1(config-if)# **ip address** 172.17.99.11 255.255.255.0
S1(config-if)# **ipv6 address** 2001:db8:acad:99::1 /64
S1(config-if)#**no shutdown**

Attention que le commutateur peut avoir besoin d'être configuré pour IPv6 !

Par exemple, sur un Cisco Catalyst 2960 fonctionnant sous IOS version 15.0, vous devrez entrer la commande de configuration globale **sdm prefer dual-ipv4-and-ipv6 default** et ensuite redémarrer celui-ci à l'aide de la commande **reload**.

Etape 2 : Le commutateur doit être configuré avec une passerelle par défaut s'il doit être géré à distance depuis des réseaux connectés indirectement. La passerelle par défaut est le routeur auquel le commutateur est connecté directement.

S1(config)# **ip default-gateway** *172.17.99.1*

Etape 3 : Dès qu'une modification a été faite au niveau de la configuration du matériel, il est indispensable de vérifier si celle-ci est correcte et opérationnelle.
Dans notre cas, nous pouvons vérifier cela à l'aide de la commande :

S1# **show ip interface brief**
S1# **show ipv6 interface brief**

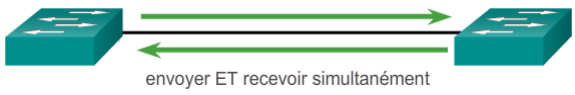
Finalement, si tout fonctionne, il ne vous reste plus qu'à sauvegarder la nouvelle configuration en cours (running-config) en tant que configuration de démarrage (startup-config) afin que votre commutateur se souvienne votre configuration après un redémarrage.

S1# **copy running-config startup-config**

source destination

Configuration des ports d'un commutateur

Les communications bidirectionnelles simultanées (full-duplex) améliorent les performances d'un réseau LAN commuté. Les communications bidirectionnelles simultanées augmentent la bande passante réelle car les deux extrémités de la connexion transmettent et reçoivent simultanément des données.



Les communications bidirectionnelles non simultanées (half-duplex) sont unidirectionnelles, c-à-d que l'envoi et la réception de données n'ont jamais lieu simultanément. Ce type de communication entraîne des problèmes de performances car les données ne peuvent circuler que dans un sens à la fois, ce qui se traduit souvent par des collisions.



Les connexions bidirectionnelles non simultanées se rencontrent généralement dans du matériel ancien, tel que des concentrateurs (hubs). La plupart des cartes réseau Ethernet et Fast Ethernet commercialisées aujourd'hui permettent les communications bidirectionnelles simultanées.

A noter que les cartes réseau Gigabit Ethernet et 10Gb fonctionnent obligatoirement en mode bidirectionnel simultané.

En mode full-duplex, les trames transmises par les deux périphériques connectés ne peuvent entrer en collision puisque ces derniers utilisent deux circuits distincts sur le câble réseau.

→ le mode full-duplex offre une efficacité de 100 % dans les deux sens.

Bien entendu, les connexions bidirectionnelles simultanées nécessitent un commutateur qui prend en charge la configuration bidirectionnelle simultanée !

HEH be Sciences et technologies

Chapitre 1

Les ports de commutateur peuvent être configurés manuellement avec des paramètres de bidirectionnalité et de vitesse spécifiques.

Le paramètre de bidirectionnalité et de vitesse d'un port de commutateur Cisco Catalyst 2960 ou 3560 est auto. Les ports 10/100/1000 fonctionnent soit en mode bidirectionnel non simultané, soit en mode bidirectionnel simultané lorsqu'ils sont définis à 10 ou 100 Mbit/s.

Par contre, à 1000 Mbit/s (1 Gbit/s), ils fonctionnent uniquement en mode bidirectionnel simultané. La négociation automatique est utile lorsque les paramètres de vitesse et de transmission bidirectionnelle du périphérique connecté au port sont inconnus ou susceptibles de changer.

Lors d'une connexion à des équipements connus, tels que des serveurs, des postes de travail dédiés ou des périphériques réseau, il est recommandé de régler manuellement les paramètres de vitesse et de transmission bidirectionnelle.

Exemple de configuration manuelle :

S1(config)# **interface** FastEthernet 0/1
S1(config-if)#**duplex** full
S1(config-if)#**speed** 100

Pour vérifier, il suffit de faire un **show running config**

Remarque : toute incohérence entre les paramètres de bidirectionnalité et de vitesse peut entraîner des problèmes de connectivité. L'échec de la négociation automatique produit des réglages incohérents.

Echec de l'autonégociation ?

- Affectation de la valeur par défaut (en fonction du fabricant)
exemple : 10BASE-T = half-duplex, 100BASE-FX = full-duplex

- Half duplex + full duplex
Entraîne des erreurs de collision à l'extrémité en mode bidirectionnel non simultané

Rappel sur le câblage :

Type de câble	Standard	Application
Ethernet droit	Les deux extrémités T568A ou T568B	Connexion d'un hôte réseau à un périphérique réseau tel qu'un commutateur ou un concentrateur.
Ethernet croisé	Une extrémité T568A, l'autre T568B	Connexion de deux hôtes réseau. Connexion de deux périphériques intermédiaires réseau (un commutateur à un commutateur, ou un routeur à un routeur).
Renversement	Exclusif à Cisco	Connexion d'un port série de station de travail à un port console de routeur, à l'aide d'un adaptateur.

Nous avons vu au bloc 1, qu'il était nécessaire d'utiliser certains types de câble (droit ou croisé) pour connecter les périphériques.

→ on ne devait pas utiliser le même câble pour connecter deux commutateurs ensemble ou un commutateur et un routeur.

A présent, la fonctionnalité d'interface croisée dépendante du support (auto-MDIX) d'une interface permet d'éliminer ce problème.

Lorsque la fonction auto-MDIX est activée, l'interface détecte automatiquement le type de câble requis pour la connexion (droit ou croisé) et configure la connexion en conséquence.

Sur les routeurs et les commutateurs Cisco les plus récents, la commande du mode de configuration d'interface **mdix auto** permet d'activer cette fonctionnalité. Lorsque la fonctionnalité auto-MDIX est utilisée sur une interface, la vitesse de l'interface et le mode de bidirectionnalité doivent être réglés sur **auto** pour un fonctionnement correct.

Remarque : la fonctionnalité auto-MDIX est activée par défaut sur les commutateurs Cisco Catalyst 2960 et 3560, mais n'est pas disponible sur les anciens commutateurs Cisco Catalyst 2950 et 3550.

Pour l'activer, il suffit d'utiliser les commandes suivantes :

S1(config)# **interface** FastEthernet 0/1
S1(config-if)#**duplex** auto
S1(config-if)#**speed** auto
S1(config-if)#**mdix** auto

Si vous souhaitez vérifier le paramètre auto-MDIX d'une interface donnée :

```
S1# show controllers ethernet-controller fa0/1 phy | include MDIX
 Auto-MDIX : On [AdminState=1 Flags=0x00052248]
```


Rappel des commandes intéressantes de vérification des commutateurs :

Commandes IOS de commutateur Cisco	
Afficher l'état et la configuration des interfaces.	S1# **show interfaces**[*interface-id*]
Afficher la configuration initiale actuelle.	S1# **show startup-config**
Afficher la configuration en cours.	S1# **show running-config**
Afficher les informations sur le système de fichiers Flash.	S1# **show flash**
Afficher l'état matériel et logiciel du système.	S1# **show version**
Afficher l'historique des commandes exécutées.	S1# **show history**
Afficher les informations IP d'une interface.	S1# **show ip** [*interface-id*]
Afficher la table d'adresses MAC.	S1# **show mac-address-table** OU S1# **show mac address-table**

La commande **show interfaces** est une commande souvent utilisée pour détecter les éventuels problèmes.

L'un des points les plus importants de ce résultat est l'affichage de l'état de la ligne et du protocole de liaison de données.

```
S1# show interfaces FastEthernet0/1
FastEthernet0/1 is up, line protocol is up
```

Le premier paramètre (FastEthernet0/1 is up) fait référence à la couche matérielle et indique essentiellement si l'interface reçoit le signal « Détection de la porteuse » depuis l'autre extrémité de la connexion.

Le second paramètre (line protocol is up) fait référence à la couche de liaison de données et indique si les messages de test d'activité du protocole de couche liaison de données sont en cours de réception.

HEH be Sciences et technologies

Chapitre 1

Problèmes donnés par la commande show interfaces :

- Si l'interface est active (up) et que le protocole de ligne est désactivé (down), un problème existe tel qu'une incohérence dans le type d'encapsulation, ou l'interface de l'autre côté est peut-être en mode de désactivation des erreurs, ou il s'agit d'un problème matériel.

- Si le protocole de ligne et l'interface sont tous deux désactivés, un câble est débranché ou il existe un autre problème sur l'interface. Par exemple, une extrémité de la connexion peut être désactivée sur le plan administratif.

- Si l'interface est désactivée sur le plan administratif, cela signifie qu'elle a été désactivée manuellement (commande **shutdown**) dans la configuration courante.

La commande show interfaces permet également d'avoir des informations sur les erreurs enregistrées par le support. Certaines erreurs peuvent être suffisamment graves pour entraîner une panne du circuit, alors que d'autres peuvent entraîner une diminution sensible des performances.

Les différentes erreurs comptabilisées sont réparties en deux groupes : les erreurs constatées en entrée et celles constatées en sortie.

Exemple :

```
S1# show interfaces fastEthernet 0/18
FastEthernet0/18 is up, line protocol is up (connected)
     2295197 packets input, 305539992 bytes, 0 no buffer
     Received 1925500 broadcasts (74 multicasts)
     0 runts, 0 giants, 0 throttles
     3 input errors, 3 CRC, 0 frame, 0 overrun, 0 ignored
     0 watchdog, 74 multicast, 0 pause input
     0 input packets with dribble condition detected
     3594664 packets output, 436549843 bytes, 0 underruns
     8 output errors, 1790 collisions, 10 interface resets
     0 unknown protocol drops
     0 babbles, 235 late collision, 0 deferred
```

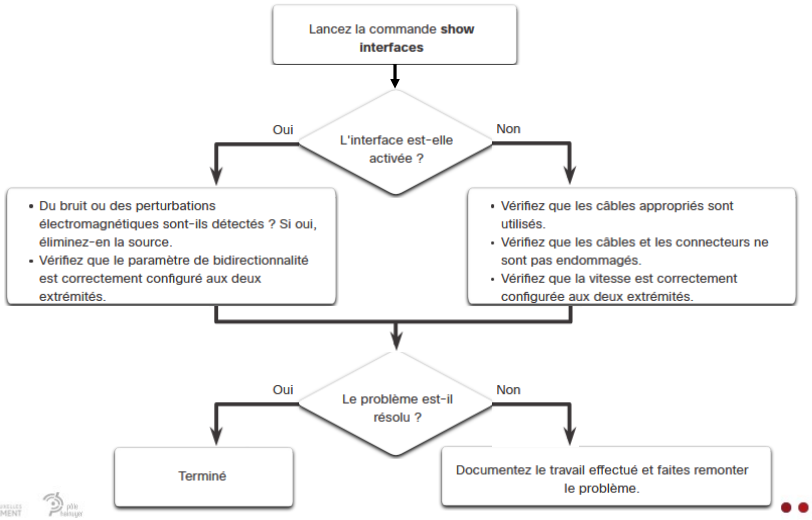

Les erreurs en entrée sont la somme de toutes les erreurs contenues dans les datagrammes reçus sur l'interface examinée. Elles comprennent les erreurs suivantes : trames incomplètes (runts), trames géantes (giants), CRC, pas de mémoire tampon, trame, débordement et comptes ignorés.

Type d'erreur	Description
Erreurs en entrée	Nombre total d'erreurs. Elles comprennent les erreurs suivantes: trames incomplètes, trames géantes, pas de mémoire tampon, CRC, trame, débordement et comptes ignorés.
Trames incomplètes	Paquets éliminés car ils sont inférieurs à la taille de paquet minimale définie pour le support. Par exemple, toute trame Ethernet inférieure à 64octets est considérée comme incomplète.
Giants	Paquets éliminés car ils sont supérieurs à la taille de paquet maximale définie pour le support. Par exemple, toute trame Ethernet supérieure à 1518octets est considérée comme «géante».
CRC	Les erreurs CRC sont générées lorsque la somme de contrôle calculée ne correspond pas à la somme de contrôle reçue.

Les erreurs en sortie sont la somme de toutes les erreurs ayant empêché la transmission finale des datagrammes vers l'interface examinée.

Type d'erreur	Description
Erreurs en sortie	Somme de toutes les erreurs ayant empêché la transmission finale des datagrammes vers l'interface examinée.
Collisions	Nombre de messages retransmis à cause d'une collision Ethernet.
Collisions tardives	Collision se produisant après que 512 octets de la trame ont été transmis.

Dépannage des problèmes de la couche accès du commutateur



Sécurisation d'un commutateur

Nous avons vu précédemment qu'il était possible, après quelques configurations, de se connecter à distance sur un commutateur.

Cependant il existe différents protocoles nous permettant de nous connecter à ce périphérique : Telnet et Secure Shell.

Telnet (utilisant le port 23) est un protocole plus ancien qui utilise un mode de transmission en texte clair non sécurisé des informations d'identification (nom d'utilisateur et mot de passe) et des données entre les périphériques qui communiquent.

Secure Shell (SSH) est un protocole qui permet d'établir une connexion sécurisée (chiffrée) pour la gestion des périphériques distants. SSH (qui utilise quant à lui le port 22) permet de sécuriser les connexions distantes grâce à une méthode de chiffrement fort pour l'authentification des périphériques (nom d'utilisateur et mot de passe), mais également pour la transmission des données entre les périphériques de communication.

Pour activer SSH sur un commutateur Cisco Catalyst 2960, le commutateur doit utiliser une version du logiciel IOS qui prend en charge les fonctionnalités de cryptographie (chiffrement).

Utilisez la commande **show version** sur le commutateur pour afficher la version du logiciel IOS exécutée par le commutateur, ainsi que le nom du fichier IOS dans lequel figure la combinaison « k9 », indiquant la prise en charge des fonctionnalités de cryptographie.

```
S1> show version
Cisco IOS Software, C2960 Software (C2960-LANBASEK9-M),
Version 15.0(2)SE, RELEASE SOFTWARE (fc1)
```

Configuration SSH :

Avant de configurer SSH, le commutateur doit au moins être configuré avec un nom d'hôte unique et avec les paramètres de connectivité réseau adéquats.

Etape 1 : Utilisez la commande **show ip ssh** pour vérifier que le commutateur prend en charge SSH. Si le commutateur ne prend pas en charge les fonctionnalités de cryptographie, cette commande n'est pas reconnue.

Etape 2 : Configurez le nom de domaine IP du réseau.

S1(config)#**ip domain-name** *nom-domaine*

Etape 3 : Générez des paires de clés RSA. Lors de la génération de clés RSA, l'administrateur est invité à saisir une longueur de module.

Cisco recommande l'utilisation d'une longueur de module minimale de 1 024 octets. Une longueur de module plus importante peut se révéler plus sûre, mais sa création et son utilisation prennent plus de temps.

Pour activer le serveur SSH sur le commutateur et pour générer une paire de clés RSA, il faut utiliser la commande :

S1(config)#**crypto key generate rsa**

Etape 4 : Le serveur SSH peut authentifier les utilisateurs localement ou avoir recours à un serveur d'authentification.

Pour utiliser la méthode d'authentification locale, créez un nom d'utilisateur et un mot de passe à l'aide de la commande :

S1(config)#**username** *nom_utilisateur* ***secret*** *password*

Etape 5 : Activez le protocole SSH sur les lignes vty à l'aide de la commande :

S1(config)#**line VTY 0 15**
S1(config-line)#**transport input ssh**
S1(config-line)#**login local**

Etape 6 : Il existe 2 versions de SSH mais bien entendu il est fortement conseillé d'utiliser la version 2 de SSH.

Pour ce faire, effectuez la commande :

S1(config)# **ip ssh version 2**

Etape 7 : Pour afficher les données de version et de configuration SSH du périphérique configuré en tant que serveur SSH, utilisez la commande **show ip ssh**.

Dans l'exemple, SSH version 2 est activé. Pour vérifier les connexions SSH vers le périphérique, utilisez la commande **show ssh**.

Lorsque tout est configuré correctement, pour vous connecter depuis un autre périphérique il faut utiliser la commande **ssh –l *username* *@ip_address*** depuis une fenêtre command prompt.

Mise à jour d'un IOS

Parfois il est nécessaire de devoir mettre à jour un IOS afin de profiter de certaines fonctionnalités particulières que possède une version par rapport à une autre.

Pour mettre à jour une version d'IOS, il va falloir procéder en plusieurs étapes :

- Il faut d'abord s'assurer que la version que l'on souhaite est présente sur un serveur TFTP et que celui-ci est correctement configuré.
- Il faut configurer le périphérique, que l'on souhaite mettre à jour, avec des paramètres réseaux appropriés.
- Pour vérifier ce qui est présent sur la mémoire flash il suffit de faire un **show flash** et pour voir la quantité de mémoire flash disponible ainsi que la version de l'IOS utilisé actuellement il faut utiliser la commande **show version**.
- Maintenant il va falloir supprimer l'IOS présent dans la flash afin de pouvoir ensuite copier la nouvelle version d'IOS que l'on souhaite utiliser.
- Pour importer la nouvelle version d'IOS il suffit d'utiliser la commande **copy tftp flash** depuis le périphérique que l'on souhaite mettre à jour.

Problèmes de sécurité dans les LAN

La sécurité de base des commutateurs n'empêche pas les attaques malveillantes.

Plus les professionnels des réseaux d'une organisation sont conscients des attaques de sécurité auxquelles ils sont confrontés et du danger qu'elles représentent, plus ils sont en mesure de les prévenir.

Nous allons donc voir quelques types d'attaques courantes dans les LAN.

Inondation d'adresses MAC

Lors du fonctionnement normal d'un commutateur, si une entrée existe pour l'adresse MAC, le commutateur transfère la trame vers le port approprié.

Si l'adresse MAC n'existe pas dans la table d'adresses MAC, le commutateur inonde tous les ports du commutateur avec la trame, à l'exception du port sur lequel la trame a été reçue.

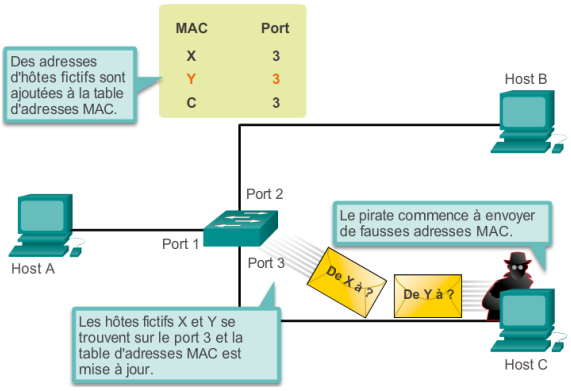
Ce comportement des commutateurs, l'inondation d'adresse MAC pour les adresses inconnues, peut être utilisé pour attaquer un commutateur. Ces attaques sont appelées attaques par débordement de la table d'adresses MAC ou attaques par inondation d'adresses MAC.

Fonctionnement :

La taille des tables d'adresses MAC étant limitée, l'inondation d'adresses MAC profite de cette limite pour submerger le commutateur de fausses adresses MAC source jusqu'à ce que la table d'adresses MAC de ce dernier soit saturée.

Lorsque la table d'adresses MAC est pleine de fausses adresses MAC, le commutateur passe en mode « fail-open ».

Dans ce mode, le commutateur diffuse l'ensemble des trames à toutes les machines du réseau. Par conséquent, le pirate peut voir toutes les trames.



Certains outils d'attaque réseau peuvent produire jusqu'à 155 000 entrées MAC par minute sur un commutateur. (La taille maximale de la table d'adresses MAC varie selon le commutateur.)

L'une des méthodes permettant d'atténuer les attaques par débordement de la table d'adresses MAC consiste à configurer la sécurité des ports.

Usurpation de DHCP

DHCP est le protocole qui affecte automatiquement à un hôte d'une adresse IP valide depuis un pool DHCP.

Deux types d'attaques DHCP peuvent être menées contre un réseau commuté : *l'épuisement des ressources DHCP* et *l'usurpation de DHCP*.

Dans **les attaques d'épuisement des ressources DHCP**, un pirate inonde le serveur DHCP de requêtes DHCP afin d'utiliser toutes les adresses IP disponibles sur le serveur DHCP.

Une fois que toutes les adresses IP ont été émises, le serveur ne peut plus fournir d'autre adresse. Cette situation se traduit par une attaque de déni de service (DoS) car les clients ne peuvent obtenir un accès au réseau.

Dans les attaques par **usurpation de DHCP**, un pirate configure un faux serveur DHCP sur le réseau pour affecter des adresses DHCP aux clients.

Cette attaque a généralement pour but de forcer les clients à utiliser un faux système de noms de domaine (DNS) et d'utiliser le serveur du pirate, ou une machine contrôlée par ce dernier, comme passerelle par défaut.

Pour atténuer toute attaque DHCP, faites appel aux fonctions de sécurité des ports et de surveillance DHCP disponibles sur les commutateurs.

Attaques via le protocole CDP

CDP (« Cisco Discovery Protocol ») est un protocole, de couche 2, propriétaire que tous les périphériques Cisco peuvent utiliser.

Le protocole CDP détecte tous les autres périphériques Cisco connectés directement, ce qui leur permet de procéder à la configuration automatique de leur connexion.

Par défaut, le protocole CDP est activé sur tous les ports de la plupart des routeurs et des commutateurs Cisco.

Les informations CDP sont envoyées régulièrement via des diffusions non chiffrées et sont mises à jour localement dans la base de données CDP de chaque périphérique.

CDP renferme des informations sur le périphérique, notamment son adresse IP, la version du logiciel IOS, la plate-forme, les fonctions et le VLAN natif.

Ces informations peuvent être utilisées par un pirate afin d'attaquer le réseau, généralement par une attaque de déni de service (DoS).

Il est recommandé de désactiver le protocole CDP sur les périphériques ou les ports sur lesquels il n'est pas requis (CDP peut être désactivé port par port), à l'aide de la commande :

S1(config)#**no cdp run**

Attaques via telnet

Le protocole Telnet n'est pas sécurisé, un pirate peut ainsi l'utiliser pour accéder à distance à un périphérique réseau Cisco.

Il existe des outils à l'aide desquels un pirate informatique peut lancer une attaque de décodage en force des mots de passe des lignes vty sur le commutateur.

Telnet peut également être utilisé pour lancer une attaque de déni de service (DoS).

Dans une attaque DoS Telnet, le pirate exploite une faille d'un logiciel serveur Telnet exécuté sur le commutateur qui rend le service Telnet indisponible.

Ce type d'attaque empêche l'administrateur d'accéder à distance aux fonctions de gestion du commutateur.

Ce type d'attaque peut être combiné avec d'autres attaques directes sur le réseau dans le cadre d'une tentative coordonnée pour empêcher l'administrateur réseau d'accéder à des périphériques principaux pendant une faille de sécurité.

Les vulnérabilités du service Telnet qui autorisent les attaques DoS sont généralement traitées au moyen de correctifs de sécurité inclus dans les nouvelles versions révisées du logiciel Cisco IOS.

HEH be Sciences et technologies

Chapitre 1

Attaque de mot de passe en force

Aussi appelé attaque par « force brute », son fonctionnement est des plus basiques puisqu'il s'agit de tester, une à une, toutes les combinaisons possibles.

En général, la première phase de ce type d'attaque consiste pour le pirate à utiliser une liste de mots de passe courants (« attaque par dictionnaire »), ainsi qu'un programme conçu pour tenter d'établir une session Telnet au moyen de chaque mot figurant dans la liste du dictionnaire.

Si le mot de passe n'est pas découvert lors de la première phase, une seconde phase débute.

Lors de la deuxième phase de l'attaque en force, le pirate fait appel à un programme chargé de créer des combinaisons de caractères séquentielles pour tenter de deviner le mot de passe.

Lorsque le pirate dispose de suffisamment de temps, une attaque en force permet de décoder quasiment tous les mots de passe employés !

Pour lutter contre ce type d'attaque, il est conseillé d'utiliser des mots de passe forts (c-à-d constitué de lettres majuscules et minuscules, de chiffres et de caractères spéciaux) et de les changez régulièrement. En plus de cela, l'accès aux lignes vty peut également être limité à l'aide d'une liste de contrôle d'accès.

Meilleures pratiques de sécurité dans les LAN

Les meilleures pratiques de sécurisation du réseau sont les suivantes :

- Développez une stratégie de sécurité écrite pour l'organisation.
- Arrêtez les services et les ports inutilisés.
- Utilisez des mots de passe forts et modifiez-les régulièrement.
- Contrôlez l'accès physique aux périphériques.
- Evitez de vous connecter à des sites Web HTTP non sécurisés, préférez les écrans de connexion qui utilisent le protocole HTTPS.
- Effectuez des sauvegardes et testez les fichiers enregistrés de façon régulière.
- Eduquez les employés à propos des attaques par manipulation psychologique, et développez des stratégies de validation des identités par téléphone, par e-mail, et en personne.
- Chiffrez et protégez par mot de passe les données sensibles.
- Implémentez des logiciels et des matériels de sécurité, tels que des pare-feu.
- Veillez à mettre les logiciels à jour en installant les correctifs de sécurité chaque semaine voire chaque jour, si possible.

HEH be Sciences et technologies

Chapitre 1

Les pratiques citées juste avant sont uniquement un point de départ pour la gestion de la sécurité. En plus de cela, il est vivement conseillé d'utiliser des outils de sécurité réseau qui vont permettent à un administrateur réseau de tester les faiblesses d'un réseau.

Certains outils permettent à un administrateur de prendre le rôle d'un pirate afin d'attaquer un réseau et de procéder à un audit des résultats, en vue de déterminer les modifications à apporter aux stratégies de sécurité pour réduire les conséquences d'une telle attaque.

L'audit de sécurité et les tests de pénétration constituent deux fonctions de base que les outils de sécurité réseau peuvent appliquer.

Ces tests/audits peuvent être effectués manuellement par l'administrateur ou automatiquement par un programme.

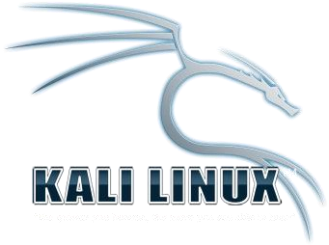
A l'aide de ces audits, l'administrateur peut, par exemple, avoir une idée du type d'informations qu'un pirate est en mesure de rassembler grâce à un simple contrôle du trafic réseau.

Il est également possible de recourir à des outils de sécurité réseau pour tester la pénétration sur un réseau.

Le test de pénétration est une attaque simulée contre le réseau permettant de déterminer le niveau de vulnérabilité en cas de véritable attaque.

Un administrateur réseau peut ainsi identifier les faiblesses de la configuration des périphériques réseau et apporter les modifications nécessaires pour rendre ces périphériques davantage résilients aux attaques.

Les attaques qu'un administrateur peut réaliser sont nombreuses et la plupart des suites d'outils offrent une documentation complète détaillant la syntaxe requise pour l'exécution de l'attaque voulue.



https://kivumakers.com/25-outils-de-test-de-penetration-de-kali-linux/

Sécurisation des ports d'un commutateur

Maintenant que nous avons parlé des problèmes de sécurité sur les LAN et des règles de bonne pratique que tout administrateur qui se respecte doit mettre en œuvre pour sécuriser au maximum son réseau, nous allons voir comment nous sécuriser les ports d'un commutateur.

Désactivation des ports inutilisés

Une méthode simple à laquelle nombre d'administrateurs ont recours pour mieux protéger le réseau contre tout accès non autorisé est de désactiver tous les ports qui ne sont pas exploités sur un commutateur.

Pour être désactivé, il suffit d'utiliser la commande :

S1(config)#**interface** FastEthernet 0/1
S1(config-if)#**shutdown**

Pour gagner du temps, s'il y a plusieurs ports successifs à désactiver, vous pouvez utiliser la commande :

S1(config)#**interface range** *type module/premier nombre – dernier nombre*

La surveillance DHCP

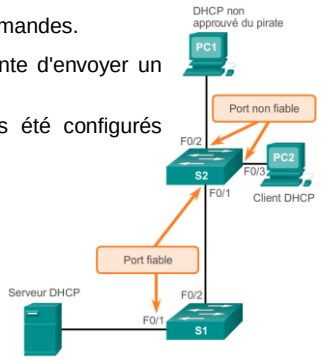
La surveillance DHCP est une fonction de Cisco Catalyst qui détermine quels ports du commutateur sont en mesure de répondre aux requêtes DHCP.

Les ports sont identifiés comme étant fiables et non fiables :

- Les ports fiables peuvent obtenir tous les messages DHCP, y compris les paquets des offres et des accusés de réception DHCP.
- Les ports non fiables peuvent uniquement obtenir les demandes.

Si un périphérique non autorisé sur un port non fiable tente d'envoyer un paquet d'offre DHCP sur le réseau, le port est arrêté.

Les ports non fiables sont tous les ports qui n'ont pas été configurés explicitement comme fiables !



Procédure :

Etape 1 : Activez la surveillance DHCP à l'aide de la commande :

S1(config)#**ip dhcp snooping**

Etape 2 : Activez la surveillance DHCP pour des VLAN spécifiques à l'aide de la commande :

S1(config)#**ip dhcp snooping vlan** *numero*

Etape 3 : définissez les ports comme étant fiables à l'aide de la commande :

S1(config)#i**nterface** FastEthernet 0/1
S1(config-if)#**ip dhcp snooping trust**

Etape 4 : Pour limiter la fréquence à laquelle un pirate peut perpétuellement transmettre de fausses requêtes DHCP au serveur DHCP via des ports non fiables, utilisez la commande :

S1(config)#i**nterface** FastEthernet 0/2
S1(config-if)# **ip dhcp snooping limit rate** *fréquence*

La sécurisation des ports utilisés

L'une des méthodes de sécurisation des ports consiste à implémenter une fonctionnalité appelée **sécurité des ports**.

La sécurité des ports restreint le nombre d'adresses MAC autorisées sur un port.

→ les adresses MAC des périphériques légitimes sont ainsi autorisées.

→ toutes les autres adresses MAC sont refusées.

Il existe plusieurs façons de configurer la sécurité des ports. Le type d'adresse sécurisée est basé sur une des configurations suivantes :

▪ **Adresses MAC sécurisées statiques** : adresses MAC configurées manuellement sur un port à l'aide de la commande :

S1(config)# **switchport port-security mac-address** *@adresse-mac*

Les adresses MAC configurées de cette manière sont stockées dans la table d'adresses et sont ajoutées à la configuration en cours sur le commutateur.

▪ **Adresses MAC sécurisées dynamiques** : adresses MAC apprises de manière dynamique et stockées uniquement dans la table d'adresses. Les adresses MAC configurées ainsi sont supprimées au redémarrage du commutateur.

▪ **Adresses MAC sécurisées rémanentes** : adresses MAC pouvant être apprises de manière dynamique ou configurées manuellement, puis stockées dans la table d'adresses et ajoutées à la configuration en cours.

Pour configurer une interface dans le but de convertir des adresses MAC apprises de manière dynamiques en adresses MAC sécurisées rémanentes et les ajouter à la configuration en cours, vous devez activer l'apprentissage rémanent :

S1(config)#**interface** FastEthernet 0/1
S1(config-if)# **switchport port-security mac-address sticky**

Une fois cette commande exécutée, le commutateur convertit toutes les adresses MAC apprises de manière dynamique, y compris les adresses apprises avant l'activation de l'apprentissage rémanent, en adresses MAC sécurisées rémanentes.

Les adresses MAC sécurisées rémanentes peuvent également être définies manuellement :

S1(config-if)# **switchport port-security mac-address sticky** *@adresse-mac*

Si les adresses MAC sécurisées rémanentes sont enregistrées dans le fichier de configuration initiale, alors, lorsque le commutateur est redémarré ou lorsque l'interface est désactivée, l'interface n'a pas à réapprendre les adresses.

Remarque : La sécurité des ports peut être configurée pour autoriser une ou plusieurs adresses MAC à l'aide de la commande :

S1(config-if)#**switchport port-security maximum** *value*

Par défaut la valeur est à 1 mais on peut autoriser jusqu'à 3072 adresses MAC.

Attention : Rien de tout cela ne fonctionnera si la sécurité du port n'est pas au préalable activée à l'aide de la commande :

S1(config-if)# **switchport port-security**

Une fois les adresses MAC configurées sur les ports du commutateur, il y a violation de la sécurité lorsque l'une des situations suivantes se présente :

- Soit le nombre maximal d'adresses MAC sécurisées a été ajouté dans la table d'adresses de l'interface et une station dont l'adresse MAC ne figure pas dans la table d'adresses tente d'accéder à l'interface.

- Une adresse assimilée ou configurée dans une interface sécurisée est visible sur une autre interface sécurisée dans le même VLAN.

Que se passe-t-il en cas de violation de la sécurité ?

Une interface peut être configurée selon l'un des trois modes de violation suivant :

- **Protect** : lorsque le nombre d'adresses MAC sécurisées atteint la limite autorisée sur le port, les paquets munis d'adresses sources inconnues sont ignorés jusqu'à ce qu'un nombre suffisant d'adresses MAC sécurisées soit supprimé ou que le nombre maximal d'adresses à autoriser soit augmenté.

L'utilisation de ce mode ne produit aucune notification lorsqu'une violation de sécurité s'est produite.

▪ **Restrict :** lorsque le nombre d'adresses MAC sécurisées atteint la limite autorisée sur le port, les paquets munis d'adresses sources inconnues sont ignorés jusqu'à ce qu'un nombre suffisant d'adresses MAC sécurisées soit supprimé ou que le nombre maximal d'adresses à autoriser soit augmenté.

Dans ce mode, une notification indique qu'une violation de sécurité s'est produite.

▪ **Shutdown** : dans ce mode (qui est le mode par défaut), toute violation de sécurité de port entraîne immédiatement la désactivation de l'enregistrement des erreurs dans l'interface et celle de la LED du port.

Dans ce mode, le compteur de violation est incrémenté.

En résumé :

Modes de violation de sécurité

Mode de violation	Acheminement du trafic	Envoi d'un message syslog	Incrémentation du compteur de violation	Arrêt du port
Protect	Non	Non	Non	Non
Restrict	Non	Oui	Oui	Non
Shutdown	Non	Oui	Oui	Oui

Pour modifier le mode de violation d'un port de commutateur, il faut utiliser la commande :

S1(config-if)#**switchport port-security violation** *{protect | restrict | shutdown}*

Pour vérifier les paramètres de sécurité d'une interface, il suffira d'utiliser la commande :

S1#**show port-security** *[interface interface-id]*

Pour afficher toutes les adresses MAC sécurisées configurées sur toutes les interfaces de commutateur ou sur une interface définie avec informations d'obsolescence pour chacune, utilisez la commande :

S1#**show port-security address**

```
S1# show port-security address
Secure Mac Address Table
------------------------------------------------------------------
Vlan   Mac Address       Type             Ports   Remaining Age
                                                    (mins)
----   -----------       ----             -----   -------------
1      0025.83e6.4b01   SecureDynamic     Fa0/18      -
1      0025.83e6.4b02   SecureSticky      Fa0/19      -
------------------------------------------------------------------
```

Dans certains cas, lorsque la sécurité des ports est configurée sur un port, ce dernier peut passer en mode de désactivation des erreurs (Error Disabled) à la suite d'une violation.

Cela implique qu'il est désactivé et ne peut plus ni envoyer ni recevoir de trafic.

Dans ce cas, on a une série de messages relatifs à la sécurité des ports s'affiche sur la console.

Comment savoir qu'un port est passé en mode Error Disabled ?

En regardant à l'aide de la commande **show interfaces** *interface interface-id*

```
S1# show interface fa0/18 status
Port Name   Status        Vlan  Duplex  Speed   Type
Fa0/18      err-disabled  1     auto    auto    10/100BaseTX
```

Vous pouvez également trouver cette information à l'aide de la commande **show port-security interface**

```
S1# show port-security interface fastethernet 0/18
Port Security              : Enabled
Port Status                : Secure-shutdown
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 0
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 0
Last Source Address:Vlan   : 000c.292b.4c75:1
Security Violation Count   : 1
```

Pour réactiver le port, exécutez les commandes :
S1(config-if)#**shutdown**
et ensuite la commande
S1(config-if)#**no shutdown**

Chapitre 1

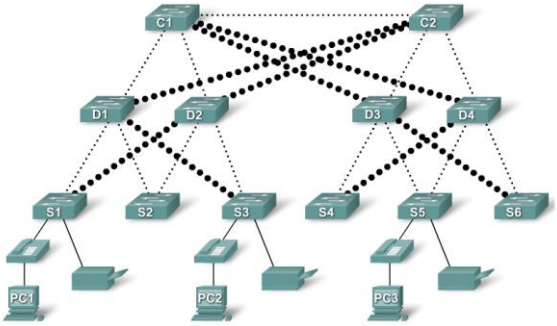
Les réseaux actuels

Les réseaux modernes ne cessent d'évoluer pour s'adapter au développement du mode de gestion des activités quotidiennes par les entreprises. Les utilisateurs veulent désormais avoir accès en tout temps aux ressources de l'entreprise. Parmi ces ressources, on retrouve bien évidemment les données traditionnelles mais aussi de la vidéo ou de la voix par exemple.

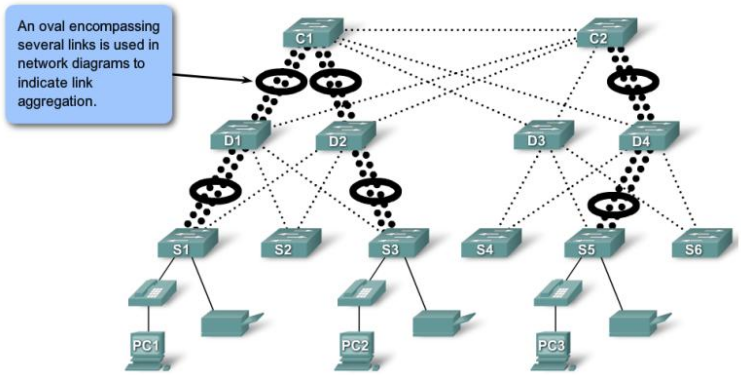
Les différents périphériques doivent fonctionner ensemble parfaitement pour fournir une connexion rapide, sécurisée et fiable entre les hôtes. On va donc commencer par examiner certains modèles actuels de conception de réseau ainsi que la manière dont les commutateurs LAN créent des tables de transfert et utilisent les informations des adresses MAC pour commuter efficacement les données entre les hôtes.

Tout d'abord un peu de vocabulaire

- **Redondance informatique** : c'est la duplication d'un élément essentiel au fonctionnement normal du système informatique, en vue de pallier la défaillance éventuelle de cet élément et d'assurer ainsi la continuité d'une fonction informatique vitale.



- **Agrégation de liens** : c'est la mise en commun de plusieurs liens reliant *les mêmes équipements* et cela afin d'augmenter le débit entre ces 2 équipements.

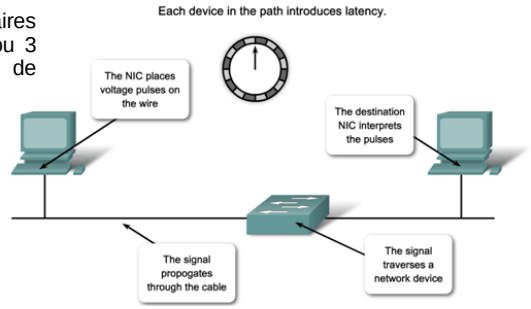


Par exemple : si on configure 2 liens 100 Mb/s entre 2 équipements, on peut créer une liaison de 200 Mb/s.

- La **latence** est le temps nécessaire à une trame ou à un paquet pour circuler entre la station source et sa destination finale.

Causes de latence :

- délai de la carte réseau
- délai de propagation sur le câble
- les périphériques intermédiaires traversés (nombre, couches 2 ou 3 du modèle OSI, mode de commutation choisi,…)



Chapitre 1

- La **congestion** (goulot d'étranglement) est l'état dans lequel les ressources du réseau (mémoire, liaison) sont pratiquement toutes occupées (≈ embouteillage).

La congestion survient lorsque la capacité d'un réseau est dépassée par la demande.
Ce qui se produit notamment dans un des cas suivants :

- Nombre important de nœuds
- Trafic soutenu
- Taux de diffusions important
- Taux de collisions important

Chapitre 1

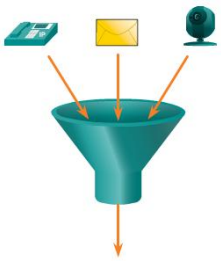
Actuellement, les réseaux d'entreprise doivent avoir recours à des solutions convergentes utilisant des systèmes vocaux, des téléphones IP, la vidéo et la vidéoconférence,…

Il y a plusieurs avantages à l'utilisation d'un réseau convergent :

- entraîne des économies considérables, par rapport à l'installation et à la gestion de réseaux distincts pour la voix, la vidéo et les données.

- installation et gestion d'un seul réseau physique.

Plusieurs types de trafic



Réseau convergent

Chapitre 1

Comme vous pouvez vous en doutez, la création d'un réseau n'est pas une simple accumulation de commutateurs et de routeurs !

Elle exige l'utilisation de principes de conception de réseaux robustes, pour assurer une disponibilité, une flexibilité, une sécurité et une facilité de gestion optimales.

Le réseau doit pouvoir répondre aux besoins actuels et prendre en charge les services et technologies ultérieurement requis. Les directives de conception de réseaux reposent sur les principes suivants :

- **Hiérarchie** : faciliter la compréhension du rôle de chaque périphérique à chaque niveau, simplifier le déploiement, l'exploitation et la gestion, tout en réduisant les domaines défaillants à chaque niveau.
- **Modularité** : permettre l'extension transparente du réseau et l'activation de services intégrés à la demande.
- **Résilience** : assurer que le réseau reste toujours actif, pour répondre aux attentes des utilisateurs.
- **Flexibilité** : utiliser toutes les ressources du réseau, afin de répartir avec intelligence la charge de trafic.

Ces principes ne sont pas indépendants. Il est essentiel de comprendre comment chaque principe s'insère dans le contexte des autres.

La conception hiérarchisée d'un réseau établit une base sur laquelle les concepteurs de réseaux peuvent ajouter des fonctionnalités de sécurité, de mobilité et de communications unifiées.

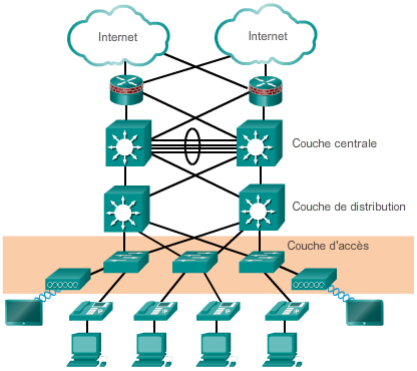
Quel est donc la solution ?

Comment construire un réseau qui va me permettre d'isoler rapidement les problèmes ?

Être simple à administrer ?

Modulable et évolutif ?

Grâce à l'utilisation de modèles en trois couches (voire parfois en deux couches lorsque les deux couches supérieures sont regroupées)



Les trois couches critiques dans ces conceptions à plusieurs niveaux sont appelées :

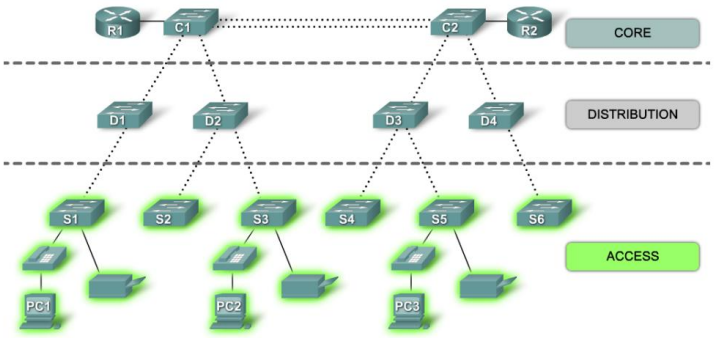
- ✓ **la couche d'accès,**
- ✓ **la couche de distribution,**
- ✓ **la couche cœur du réseau**.

Chaque couche peut être considérée comme un module bien défini et structuré, avec des rôles et des fonctions spécifiques dans le réseau de campus.

La couche accès

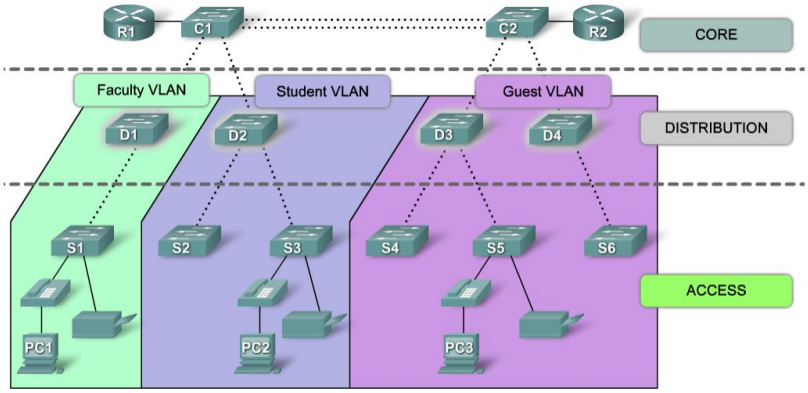
La couche accès a pour but de fournir aux périphériques finaux un moyen de se connecter au réseau.

C'est elle qui va également contrôler les périphériques autorisés à communiquer sur ce réseau. Au niveau de cette couche on peut retrouver toute sorte de périphériques (routeurs, commutateurs, points d'accès sans fil,…)



La couche distribution

La couche de distribution établit l'interface entre la couche d'accès et la couche cœur de réseau.

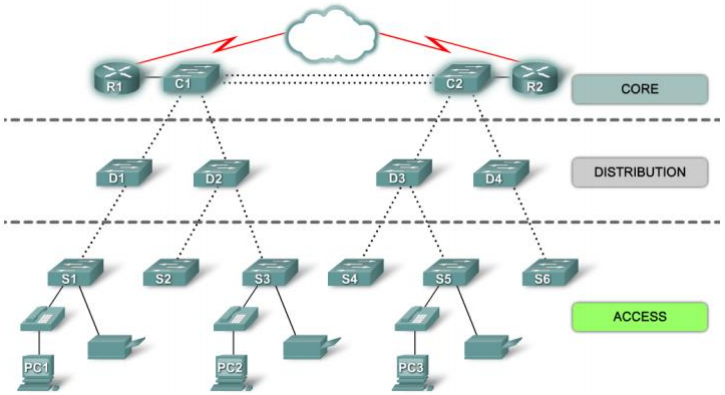


Les fonctions importantes de cette couche distribution sont notamment :

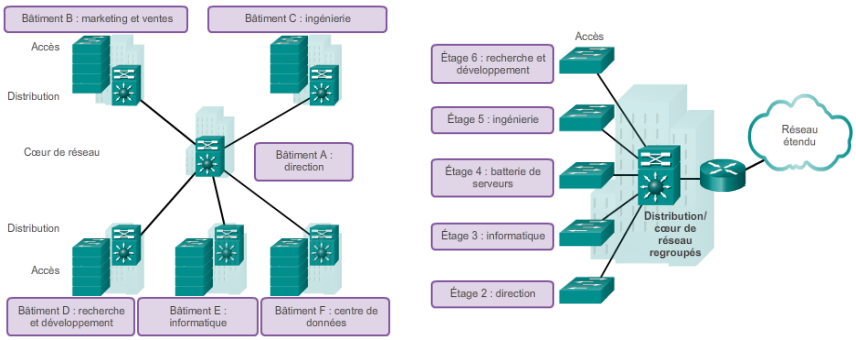
- Regroupement de réseaux étendus d'armoires de câblage.
- Regroupement des domaines de diffusion (zones de broadcast) de couche 2 et des limites de routage de couche 3.
- Fonctions intelligentes de commutation, de routage et de règles d'accès au réseau, pour l'accès au reste du réseau.
- Haute disponibilité pour l'utilisateur final et chemins à coût égal vers le cœur de réseau au moyen de commutateurs redondants dans la couche de distribution.
- Services différenciés, pour différentes classes d'applications de services à la périphérie du réseau.

La couche cœur

La couche cœur de réseau sert de réseau fédérateur (backbone). Elle connecte plusieurs couches du réseau de campus. La couche cœur de réseau sert d'agrégateur pour tous les autres blocs de campus et joint le campus au reste du réseau.

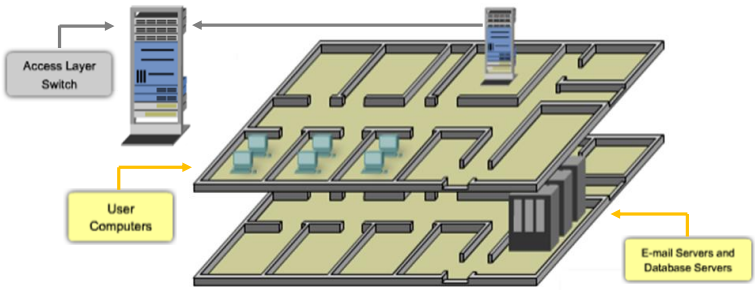


La couche cœur de réseau a pour objectifs principaux de transférer les données le plus rapidement possible et d'apporter une connexion à Internet ainsi qu'aux autres réseaux de la société, via une connexion MAN ou WAN.



Exemple de représentation physique d'un réseau hiérarchique

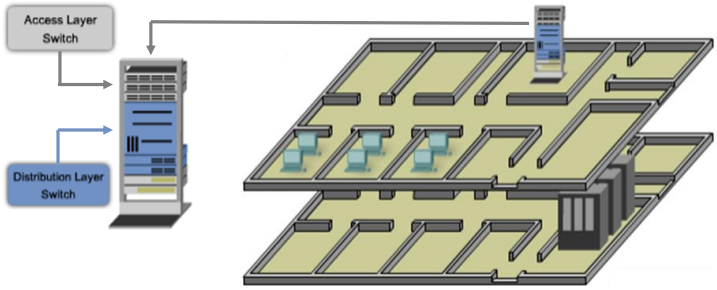
On a par exemple deux étages au niveau d'une entreprise.



On retrouvera bien entendu des périphériques finaux destinés aux utilisateurs du réseau à chaque étage.

En plus de cela on retrouvera également d'autres périphériques finaux tels que des serveurs.

Ces périphériques seront directement connectés à des commutateurs appartenant à la couche accès.



Les commutateurs de couche accès seront eux connectés à des commutateurs de la couche de distribution. Généralement dans une salle de brassage au niveau de chaque étage.

Tous les commutateurs de la couche distribution des différents étages seront ensuite reliés à la couche cœur.

Chapitre 1

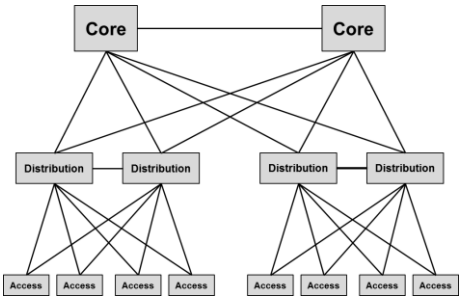
Les avantages d'un réseau hiérarchique

- **Evolutivité** : La modularité de la conception permet de reproduire des éléments de conception au fur et à mesure de l'évolution du *réseau*.
- **Redondance** : les services doivent être opérationnel 24/24. Le fait de mettre en place de la redondance au niveau des couches principales et de distribution garantit la disponibilité de chemins d'accès.

Des commutateurs de couche d'accès sont connectés à deux commutateurs de couche de distribution différents, afin de garantir une redondance du chemin d'accès.

Lorsque l'un des commutateurs de la couche de distribution devient inopérant, le commutateur de couche d'accès peut basculer vers l'autre commutateur de couche de distribution.

En outre, des commutateurs de couche de distribution sont connectés à deux *commutateurs de couche cœur de réseau* minimum pour garantir la disponibilité du chemin d'accès en cas de défaillance d'un commutateur principal.



La seule couche où la redondance est limitée est la couche d'accès.

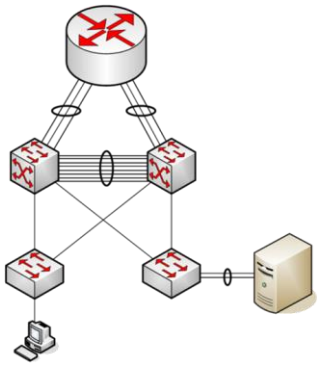
En général, les périphériques de nœud d'extrémité, tels que *les ordinateurs, les imprimantes et les téléphones sur IP*, n'offrent pas la possibilité de se connecter à plusieurs commutateurs de couche d'accès pour *la redondance*.

En cas d'échec d'un commutateur de couche d'accès, seuls les périphériques connectés à celui-ci sont affectés par la panne. Le reste du réseau peut continuer de fonctionner normalement.

- **Performances** : on évite les goulots d'étranglement

Les performances de la communication s'améliorent en évitant de transmettre les données via des commutateurs intermédiaires peu performants.

Les données sont envoyées de la couche d'accès vers la couche de distribution via des liaisons de port de commutateur agrégées.



La couche de distribution utilise ensuite ses fonctionnalités de commutation très performantes pour transférer le trafic vers la couche cœur de réseau, à partir de laquelle celui-ci est routé vers sa destination finale.

Puisque les couches cœur de réseau et de distribution effectuent leurs opérations à des vitesses très élevées, aucun conflit ne se produit au niveau de la bande passante du réseau.

- **Sécurité** : permet la sécurisation des données et des accès au plus près de la source

Comme nous avons vu précédemment, les commutateurs de couche d'accès peuvent être configurés avec différentes options de *sécurité de port*, qui permettent de contrôler les périphériques qui sont autorisés à se connecter au *réseau*.

Vous pouvez aussi utiliser des stratégies de sécurité plus avancées (à partir de la couche de distribution.

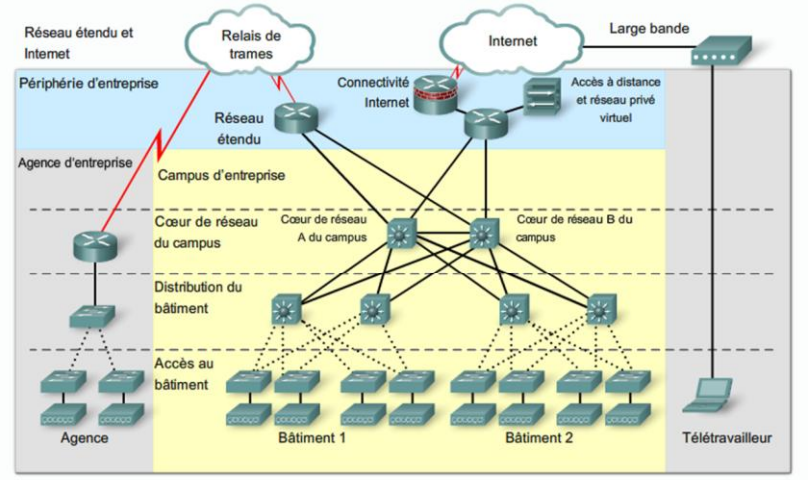
- **Administration et maintenance simplifiée**

La gestion est relativement simple sur un réseau hiérarchique étant donné que chaque couche de la conception hiérarchique remplit des fonctions spécifiques.

Par conséquent, si vous devez modifier la fonctionnalité d'un commutateur de couche d'accès, vous pouvez répéter cette modification à travers l'ensemble des commutateurs de couche d'accès dans le réseau, car ils remplissent probablement les mêmes fonctions au niveau de leur couche.

Le déploiement de nouveaux commutateurs est également simplifié, car des configurations de commutateur peuvent être copiées entre périphériques avec très peu de modifications.

Exemple d'une architecture d'entreprise :



Les réseaux commutés

Les réseaux ont fondamentalement changé, pour devenir des réseaux locaux commutés dans un réseau hiérarchique. Un réseau local commuté accroît la flexibilité, améliore la gestion du trafic et apporte des fonctions supplémentaires, notamment :

- QoS
- Sécurité supplémentaire.
- Prise en charge de réseau et de connectivité sans fil.
- Prise en charge de nouvelles technologies, telles que des services de téléphonie IP et de mobilité.

Différents types de commutateurs sont donc utilisés dans les réseaux d'entreprise.
→ Il est important de déployer des types de commutateurs adaptés aux besoins du réseau.

Quels sont, à votre avis, les facteurs qui influence le choix d'un commutateur ?

- le coût : le coût d'un commutateur dépend du nombre et de la rapidité des interfaces, des fonctionnalités prises en charge et de sa capacité d'extension.
- la densité : les commutateurs réseau doivent prendre en charge le nombre souhaité de périphériques sur le réseau.
- l'alimentation : il est désormais usuel d'alimenter les points d'accès, les téléphones IP et même des commutateurs compacts au moyen de la technologie PoE (Power over Ethernet). De plus, certains châssis permettent également d'avoir des alimentations redondantes.
- la fiabilité : le commutateur doit fournir un accès permanent au réseau.
- la vitesse des ports : la rapidité de la connexion réseau est d'une importance primordiale pour les utilisateurs finaux.
- l'évolutivité : le nombre d'utilisateurs d'un réseau évolue généralement au fil du temps → le commutateur doit donc comporter des possibilités de croissance.
- les tampons de trames : il est important qu'un commutateur enregistre les trames, dans les réseaux susceptibles d'encombrement des ports vers des serveurs ou d'autres parties du réseau.

- les fonctionnalités : commutateur de couche 2 ou multicouche, agrégation de liens,…
- Switch form factor : épaisseur du commutateur (unité U), rackable,…

Commutateur 1U



Commutateur 2U



Commutateur 3U



Quant au niveau du type de commutateur, le concepteur de réseau a du choix ! configuration fixe ou modulaire, empilable ou non empilable ?

- *les commutateurs fixes*

Les commutateurs de configuration fixe prennent en charge uniquement les fonctionnalités et les options fournies d'origine avec le commutateur.
Chaque modèle particulier détermine les fonctionnalités et les options disponibles.



Pour un commutateur de configuration fixe, il existe en général différents choix de configuration, selon le nombre et les types de ports inclus.

• *les commutateurs modulaires*

Les commutateurs de configuration modulaire apportent plus de flexibilité de configuration. En général, les commutateurs de configuration modulaire sont livrés avec des châssis de différentes tailles, qui permettent l'installation de plusieurs cartes d'interface modulaires.

La carte d'interface (qui contient les ports) s'insère dans le châssis du commutateur, comme les cartes d'extension dans un ordinateur.

Et forcément, plus la taille du châssis est importante, plus celui-ci peut contenir de modules.



• *les commutateurs empilables*

Les commutateurs de configuration empilable peuvent être interconnectés à l'aide d'un câble spécial fournissant un débit de bande passante élevé entre les commutateurs.
Grâce à la technologie Cisco StackWise, qui permet l'interconnexion de neuf commutateurs maximum, les commutateurs peuvent être empilés les uns sur les autres et connectés en chaîne par des câbles afin de fonctionner comme un unique commutateur plus important.

Ils sont recommandés lorsque la tolérance aux pannes et la disponibilité de la bande passante constituent des éléments essentiels, et que l'implémentation d'un commutateur modulaire représente une dépense trop importante.



De nombreux commutateurs empilables Cisco prennent également en charge la technologie StackPower, qui permet de répartir l'énergie parmi les membres de la pile.

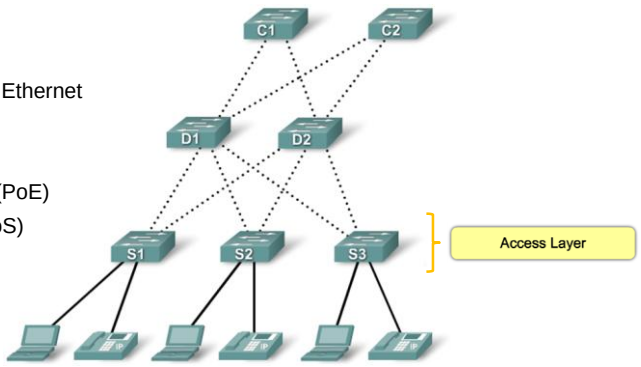
particularités des commutateurs empilables :

- 1 seule adresse IP de gestion (qui n'est pas liée à un commutateur).
- Table de commutation partagée..
- Représente un seul switch pour le Spanning Tree Protocol.
- L'ajout de commutateurs n'augmente pas le diamètre réseau.

Bien entendu, vous l'aurez compris, il y a un tas de paramètres qui interviennent dans le choix des commutateurs à utiliser. Et en fonction de la couche dans laquelle on compte utiliser le commutateur, on recherchera des fonctionnalités différentes.

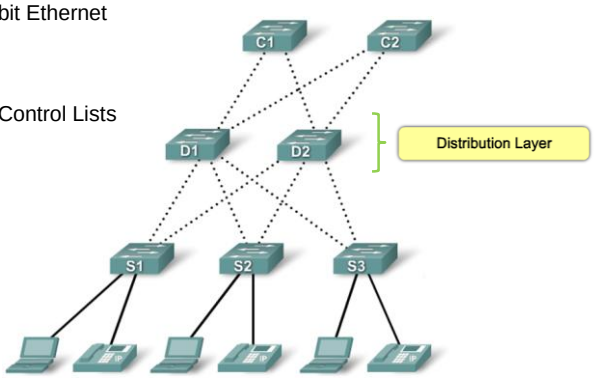
Pour la couche accès par exemple, on prendra des commutateurs possédant des fonctions tels que :

- ✓ VLANs
- ✓ Fast Ethernet/Gigabit Ethernet
- ✓ Port security
- ✓ Link aggregation
- ✓ Power over Ethernet (PoE)
- ✓ Quality of Service (QoS)



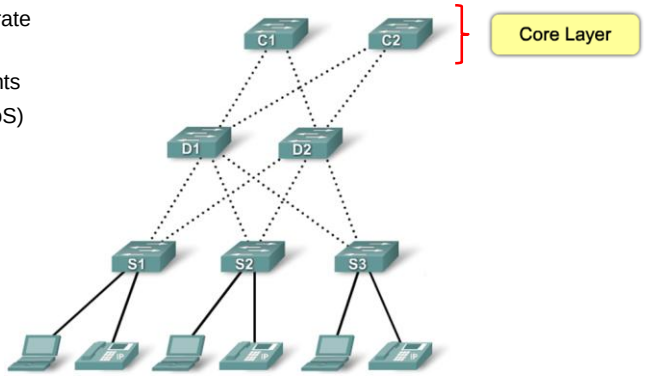
Pour la couche de distribution par exemple, on prendra des commutateurs possédant des fonctions tels que :

- ✓ Switch Layer 3
- ✓ Gigabit Ethernet/10 Gigabit Ethernet
- ✓ High forwarding rate
- ✓ Link aggregation
- ✓ Security policies/Access Control Lists
- ✓ Redundant components
- ✓ Quality of Service (QoS)



Pour la couche cœur par exemple, on prendra des commutateurs possédant des fonctions tels que :

- ✓ Switch Layer 3
- ✓ Gigabit Ethernet/10 Gigabit Ethernet
- ✓ Very high forwarding rate
- ✓ Link aggregation
- ✓ Redundant components
- ✓ Quality of Service (QoS)

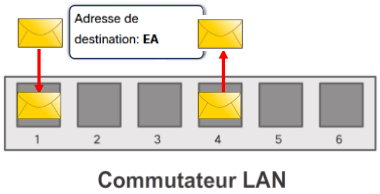


Le transfert de trames

Le concept de commutation et de transfert de trames est universel dans les réseaux et les télécommunications. Différents types de commutateurs sont utilisés dans les réseaux LAN, WAN et le réseau téléphonique public commuté (RTPC). Le concept fondamental de commutation désigne un périphérique effectuant une décision en fonction de deux critères :

- Port d'entrée (Ingress)
- Port de sortie (Egress)

Un commutateur LAN gère une table (appelée table de commutation) qu'il utilise pour déterminer l'acheminement du trafic.



Commutateur LAN

Table des ports:

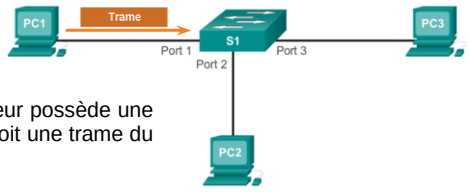
Adresses de destination	Port
EE	1
AA	2
BA	3
EA	4
CA	5
AB	6

Les commutateurs utilisent des adresses MAC pour diriger les communications réseau vers la destination, via le port approprié. Pour qu'un commutateur sache vers quel port transférer une trame, il doit tout d'abord apprendre quels périphériques existent sur chaque port.

À mesure que le commutateur découvre la relation entre les ports et les périphériques, il remplit une table appelée table d'adresses MAC.

Pour rappel : un commutateur rempli sa table d'adresses MAC sur la base des adresses MAC source.

Processus de remplissage dynamique de la table d'adresses MAC :



Etape 1 : Au départ, le commutateur possède une table de commutation vide et il reçoit une trame du PC1 sur le port 1.

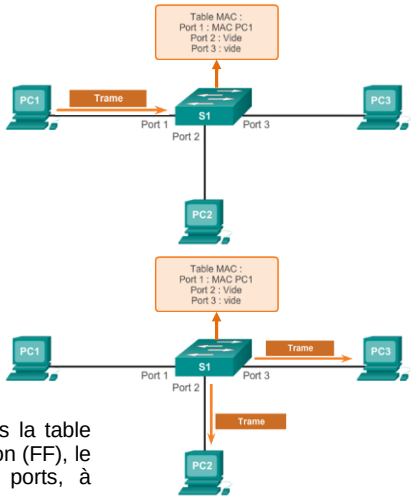
Chapitre 1

Etape 2 : Le commutateur examine l'adresse MAC source et la recherche dans la table d'adresses MAC.

- Si cette adresse ne figure pas dans la table d'adresses MAC, il associe l'adresse MAC source du PC 1 au port d'entrée (port 1) dans la table d'adresses MAC.
- Si la table d'adresses MAC comporte déjà une entrée pour cette adresse source, il réinitialise le compteur. (5 min)

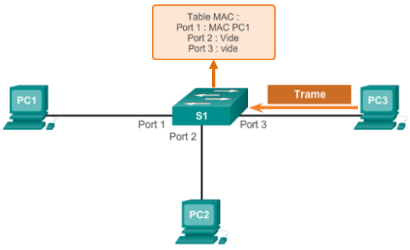
Etape 3 : Après avoir enregistré les informations d'adresse source, le commutateur examine l'adresse MAC de destination.

- Si l'adresse de destination ne figure pas dans la table MAC ou s'il s'agit d'une adresse MAC de diffusion (FF), le commutateur transfère la trame à tous les ports, à l'exception du port d'entrée.

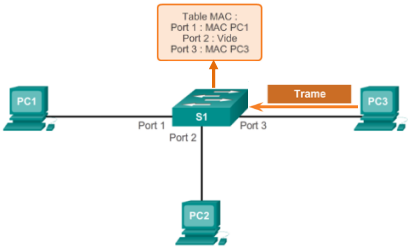


Chapitre 1

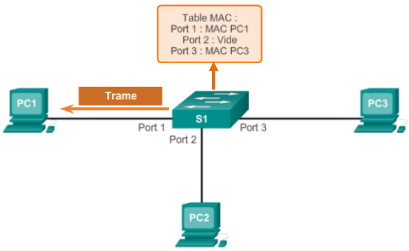
Etape 4 : Le périphérique de destination (PC 3) répond à la trame avec une trame de monodiffusion destinée au PC 1.



Etape 5 : Le commutateur enregistre, dans la table d'adresses, l'adresse MAC source du PC 3 et le numéro de port d'entrée. L'adresse de destination de la trame et le port de sortie qui lui est associé se trouvent dans la table d'adresses MAC



Etape 6 : Le commutateur peut désormais transférer les trames entre ces périphériques source et de destination, sans inondation, car il dispose d'entrées dans la table d'adresses qui identifient les ports associés.



Méthodes de transfert de trames

Ce que nous venons de revoir est le principe général du fonctionnement de tous les commutateurs. Nous allons maintenant voir qu'il existe différentes méthodes de transfert de trames :

▪ la méthode du « store and forward » (stockage et retransmission) décide de transférer une trame après avoir reçu la trame complète et après avoir contrôlé l'absence d'erreurs.

→ Réception de la trame en entier → CRC → adresse de destination → interface de sortie

▪ la méthode « cut-through » lance le processus de transfert dès que l'adresse MAC de destination d'une trame entrante et le port de sortie sont déterminés.

→ Réception du début de la trame → lecture adresse destination → transfert

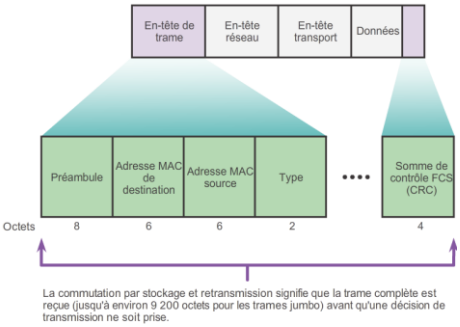
Méthode du Store and forward

La commutation par stockage et retransmission présente deux caractéristiques principales qui la distinguent de la commutation cut-through : le **contrôle des erreurs** et la **mise en tampon automatique**.

La commutation par stockage et retransmission contrôle l'absence d'erreurs sur une trame entrante.

Pour ce faire, le commutateur compare la valeur du dernier champ du datagramme reçu (FCS pour « frame check sequence ») avec ses propres calculs de FCS afin de vérifier que la trame est exempte d'erreurs physiques et de liaison de données.

- Si la trame est exempte d'erreurs, le commutateur transfère la trame.
- Si tel n'est pas le cas, la trame est abandonnée !



La mise en tampon des ports d'entrée, utilisée par les commutateurs à stockage et retransmission, est nécessaire pour prendre en charge toute combinaison de vitesses Ethernet.

Dès que les vitesses du port d'entrée et de sortie ne correspondent pas, le commutateur enregistre la trame complète dans une mémoire tampon, calcule le contrôle FCS, puis transmet la trame au port de sortie et l'envoie.

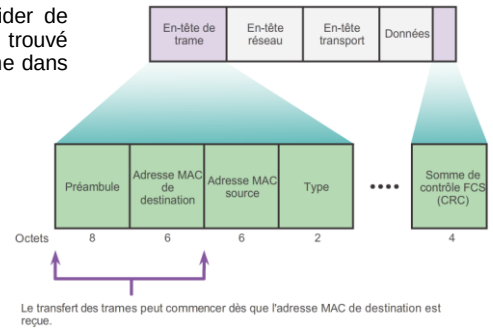
Par exemple, le traitement d'une trame arrivant sur un port Ethernet 100 Mbit/s et à transférer sur une interface 1 Gbit/s nécessite la commutation par stockage et retransmission.

Méthode Cut-through

La commutation cut-through comporte deux caractéristiques principales : la **transmission rapide des trames** et le **traitement des trames incorrectes**.

Un commutateur cut-through peut décider de transférer une trame dès qu'il a trouvé l'adresse MAC de destination de la trame dans sa table d'adresses MAC.

En cas de taux d'erreur élevé dans le réseau (trames non valides), la commutation cut-through risque d'encombrer la bande passante avec des trames endommagées et incorrectes.

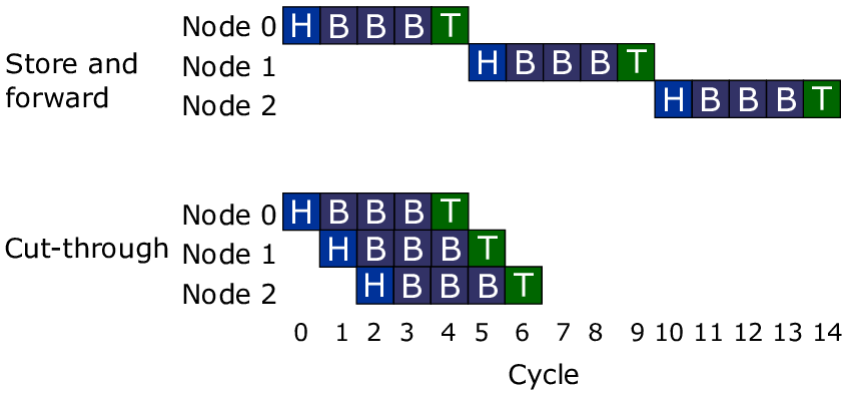


La commutation « fragment free » est une forme modifiée de la commutation cut-through, où le commutateur attend la fin de la réception de la fenêtre de collision (64 octets) avant de transférer la trame. Le champ de données de chaque trame est ainsi contrôlé, afin d'assurer qu'aucune fragmentation ne s'est produite.
La commutation fragment free assure un meilleur contrôle des erreurs que la méthode cut-through, pratiquement sans augmentation de la latence.

Grâce à son avantage de faible latence, similaire à la commutation cut-through, cette commutation est mieux adaptée aux applications HPC (« High-Performance Computing ») extrêmement exigeantes, qui nécessitent des latences de processus à processus d'au plus 10 microsecondes.

Remarque :
Un commutateur cut-through risque de transférer des trames non valides car il n'effectue aucun contrôle FCS.

Comparaison entre les méthodes de transfert de trames.



Domaine de commutation

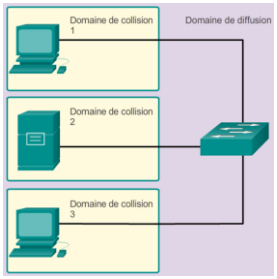
Pour rappel, dans les segments Ethernet basés sur des concentrateurs, les périphériques réseau sont en concurrence pour le support, car ils doivent transmettre à tour de rôle, sous peine de provoquer une collision. Les segments de réseaux partageant la même bande passante entre périphériques sont appelés des **domaines de collision**.

Pour diviser un réseau en segments et de réduire le nombre de périphériques qui partagent la bande passante, il convient d'utiliser d'autres périphériques réseau (par exemple des commutateurs).

Si un port de commutateur Ethernet fonctionne en mode bidirectionnel non simultané, chaque segment est dans son propre domaine de collision.

Il n'y a pas de domaine de collision lorsque les ports de commutateur fonctionnent en duplex intégral.

Par défaut, les ports des commutateurs Ethernet s'auto-négocient en duplex intégral lorsque le dispositif adjacent peut également fonctionner en duplex intégral.



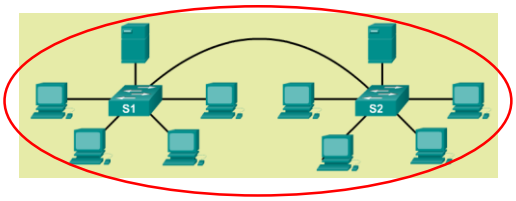
Si les commutateurs filtrent la plupart des trames sur la base des adresses MAC dont ils disposent, ils ne filtrent pas en revanche les trames de diffusion.

Un ensemble de commutateurs interconnectés constitue un **domaine de diffusion** unique.

Seul un périphérique de couche réseau (de couche 3), tel qu'un routeur, peut diviser un domaine de diffusion de couche 2.

Les routeurs sont utilisés pour segmenter les domaines de collision et les domaines de diffusion.

Les diffusions sont parfois nécessaires pour localiser initialement d'autres équipements et services réseau, mais un nombre de diffusions trop élevés sur un réseau peuvent entraîner un encombrement, c'est-à-dire un ralentissement des performances réseau.



1 seul domaine de diffusion

Cependant l'utilisation de commutateurs contribue à réduire la congestion du réseau, grâce notamment à leurs caractéristiques tels que :

- une densité de ports élevée : les commutateurs possèdent une grande densité de ports. Souvent, des commutateurs à 24 et à 48 ports occupent seulement 1 unité de rack (1,75 cm) en hauteur.
- la vitesse des ports : un commutateur, selon son coût, peut prendre en charge plusieurs combinaisons de vitesses. Les ports de 100 Mbit/s et de 1 ou 10 Gbit/s sont courants (une vitesse de 100 Gbit/s est également possible).
- un faible coût par port : les commutateurs offrent une densité de ports élevée à moindre coût. On peut donc concevoir des réseaux qui vont desservir moins d'utilisateurs par segment, ce qui augmentera la bande passante moyenne disponible par utilisateur.
- une commutation interne rapide : les possibilités internes de transfert rapide permettent de hautes performances. L'utilisation d'un bus interne rapide ou d'une mémoire partagée améliore les performances globales du commutateur.
- des tampons de trames étendus : l'enregistrement de plusieurs trames avant de commencer à les abandonner est particulièrement utile en présence de ports encombrés vers des serveurs ou d'autres parties du réseau.

Notions complémentaires

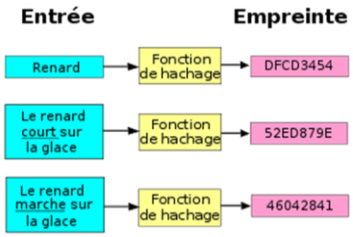
Le hachage

Une **fonction de hachage** est aussi appelée **fonction de hachage à sens unique** ou "***one-way hash function***" en anglais.

Ce type de fonction est très utilisé en cryptographie, principalement dans le but de réduire la taille des données à traiter par la fonction de chiffrement.

En effet, la caractéristique principale d'une fonction de hachage est de produire un haché des données, c'est-à-dire un condensé de données de taille fixe.

Exemple :



Principe de fonctionnement

Faisons l'analogie avec les empreintes digitales !
A l'heure actuelle, une empreinte digitale est unique et représente un individu d'une façon si certaine que nous pouvons la qualifier de sûre.

Et pourtant la connaissance de cette empreinte ne permet pas à elle-seule de remonter à l'individu, ni de reconstituer cet individu.

Pour cela, il faut préalablement qu'une correspondance ait été établie dans une base de données pour que l'identification puisse avoir lieu par comparaison.

C'est exactement le même principe utilisé par une fonction de hachage.

En effet, le haché est caractéristique d'un texte ou de données uniques.
→ *Différentes données donneront toutes des condensés différents*.

De plus, tout comme l'empreinte digitale, le condensé ne contient pas assez d'informations en lui-même pour permettre la reconstitution du texte original : c'est pour cela que l'on parle d'ailleurs de fonction à sens unique (l'opération de hachage est destructrice dans le sens où elle conduit à une perte d'information).

HEH be Sciences et technologies

Chapitre 1

Mais il faut bien comprendre que le but d'un condensé n'est pas de véhiculer ou de transporter de l'information.

Le but d'un condensé est simple : *représenter des données de façon certaine tout en réduisant la taille utile qui sera réellement chiffrée*.

Ok c'est bien tout ca mais pourquoi ne pas chiffrer directement l'entièreté des données que l'on souhaite transmettre de manière sécurisée ?

Simplement car chiffrer beaucoup de données avec un chiffrement correct nécessite beaucoup de ressources (CPU,…) et prend du temps !

Prenons l'exemple d'un fichier que vous souhaiteriez envoyer par email à quelqu'un tout rassurant le destinataire sur la provenance de ce fichier (c-à-d vous) ainsi que sur son contenu.

Dans ce cas de figure, on préfèrera hacher le fichier à transmettre et puis chiffrer le condensé obtenu.

Finalement vous allez envoyer votre fichier original ainsi que le condensé chiffré (la signature) à votre destinataire.

Lors de la réception, le destinataire va hacher d'une part le fichier reçu et d'autre part déchiffrer le condensé reçu.

Là il y a deux cas de figures possibles :

- Soit il y a égalité entre les deux résultats et donc il s'agit bien du message original que vous avez envoyé (→ pas de soucis)

- Soit il n'y a pas égalité entre les 2 résultats, ce qui signifiera :

  - soit que la signature n'est plus la votre, et donc que quelqu'un a intercepté le fichier (pour le modifier ou le remplacer,...)
  - soit que le fichier n'est plus le même que l'original (mais la signature n'a pas été remplacée); dans ce cas, la hachage ne peut plus donner le même condensé ce qui conduit au rejet lors du test de comparaison

  Bref, dans les 2 cas, ni l'intégrité ni l'authentification du fichier n'ont été vérifiées. Il ne faut donc pas faire confiance au fichier.

HEH.be Sciences et technologies

Chapitre 1

A travers ce cas simple vous voyez que l'utilisation d'**une fonction de hachage permet de s'assurer de l'intégrité de données.**

Bien entendu, **il existe de nombreuses autres applications pour les fonctions de hachage, stockage de mots de passe, comme les certificats et signatures numériques,…**

Quelles sont les fonctions de hachage usuelles ?

- Tout d'abord il y a le **MD5** (*Message Digest 5)* furent développées par Ron Rivest. MD5 produit des hachés de 128 bits en travaillant les données originales par blocs de 512 bits.

De nos jours, MD5 n'est donc plus considéré comme sûr au sens cryptographique. Cependant, la fonction MD5 reste encore largement utilisée comme outil de vérification lors des téléchargements et l'utilisateur peut valider l'intégrité de la version téléchargée grâce à l'empreinte.

- Une autre fonction de hachage, conçue en 1995 par la NSA, est **SHA-1** (*Secure Hash Algorithm 1*). Elle fonctionne également à partir de blocs de 512 bits de données et produit par contre des condensés de 160 bits en sortie. Elle non plus n'est plus considérée « sûr » depuis 2010.

- Il existe également RIPEMD-160 (*RACE Integrity Primitives Evaluation Message Digest*), développée en Europe et publiée en 1996. Celle-ci est une fonction de hachage qui produit une signature de 160 bits.

- Par la suite, la NSA a mis au point la famille des fonctions de hachage **SHA-2** (*Secure Hash Algorithm 2*), basé sur le SHA-1. Cette famille comporte les fonctions, **SHA-256** et **SHA-512** dont les algorithmes sont similaires mais opèrent sur des tailles de mot différentes (32 bits pour SHA-256 et 64 bits pour SHA-512) ainsi que et **SHA-384** qui est une version des précédentes dont la sortie est tronquée.

- En octobre 2012, le NIST (*National Institute of Standards and Technology*) a organisé un concours afin d'élire le futur algorithme destiné à remplacé le SHA-2, et qui s'appellera **SHA-3**. Et il s'agit de la fonction de hachage « Keccak » qui a été choisie. Une originalité de cette fonction est d'accepter en entrée à la fois des chaînes de taille arbitraire, elle inclut des sources aléatoires dans le code et elle permet en sortie des chaînes de la taille que l'on souhaite. Cet algorithme est un standard depuis 2015.

- **Whirlpool** est une fonction de hachage cryptographique en 2000 qui produit des empreintes de 512 bits. En interne, l'algorithme se base sur une fonction similaire à celle de l'algorithme de chiffrement symétrique AES, ce qui le rend robuste aux attaques.

Comment savoir quelles fonctions de hachage utiliser ?

https://www.cnil.fr/fr/securite-chiffrement-hachage-signature

Qu'est-ce qui fait qu'une fonction de hachage est dépassée ? Pourquoi existe-il-plusieurs tailles de condensés ?

Il faut garder à l'esprit le but ultime d'un haché qui est d'être le plus court possible, tout en gardant ses propriétés.

Ce qui nous amène inévitablement à aborder le problème des ***collisions*** !

Prenons donc notre haché H, qui présente une longueur de n bits. Nous pouvons d'ores et déjà déduire qu'il n'existe que 2^n hachés de ce type possibles (puisque chaque bit n'a que 2 valeurs possibles).

Le problème survient quand on se rend compte que de l'autre côté, nous pouvons avoir une infinité de textes ou données initiaux (dont la taille, elle, n'est pas fixée).

Nous risquons donc, un jour ou l'autre, de produire un haché qui pourrait correspondre à un autre texte original (ou à plusieurs) : c'est la perte de la propriété principale d'un condensé, qui est l'unicité.

Nous avons alors ce qu'on appelle une *collision*…

Il y a donc un paradoxe (appelé le paradoxe/théorème des anniversaires) qui dit qu'il faut $2^{n/2}$ essais pour trouver une collision au hasard.

Voyons voir une explication rapide de ce théorème :

Tout démarre d'une question que c'est posé Richard von Mises, savant et ingénieur au début des années 1900. Il s'est posé cette question : *dans une classe, quelle est la probabilité pour que 2 élèves fêtent leurs anniversaires le même jour ?*

Et il a donc étudier les probabilités. Quand on a 2 personnes, la première peut avoir son anniversaire n'importe quand, la seconde n'importe quel autre jour. On a donc :

$$p_2 = \frac{364}{365} = 1 - \frac{1}{365}$$

Quand on a 3 personnes, la troisième doit avoir son anniversaire un jour différent des 2 autres :

$$p_3 = \left(1 - \frac{1}{365}\right)\left(1 - \frac{2}{365}\right)$$

Et ainsi de suite, on peut réitérer le raisonnement. Pour un groupe de k personnes, on obtient :

$$p_k = \left(1 - \frac{1}{365}\right)\left(1 - \frac{2}{365}\right)\cdots\left(1 - \frac{k-1}{365}\right)$$

Ce qui nous donne ceci :

Nombre de personnes	Probabilité pour que les anniversaires tombent tous un jour différent
1	1
2	0.99
5	0.97
10	0.88
20	0.58
22	0.52
23	0.49
30	0.29
50	0.03

Au-delà de 23 personnes, la probabilité que deux personnes aient leur anniversaire qui tombe le même jour est de moins d'une chance sur deux !



Si l'on applique ce théorème aux fonctions de hachage, le haché est codé sur b bits, il y a 2^b résumés possibles. Si l'on prend k textes différents, la probabilité pour que 2 textes aient le même haché est donc :

$$1-\left(1-\frac{1}{2^b}\right)\left(1-\frac{2}{2^b}\right)\cdots\left(1-\frac{k-1}{2^b}\right)$$

→ Combien l'attaquant doit-il essayer de textes avant de trouver le même résumé avec une probabilité d'au moins une chance sur deux ?

Après approximation nous trouvons : $\exp\left(\frac{-k(k-1)}{2^b}\right) \leq \frac{1}{2}$

Ce qui donne ceci :

Taille du haché (en bits)	Nombre de textes à essayer
8	13
16	213
32	54562
64	$9{,}6\times10^{9}$
128	$1{,}5\times10^{19}$
160	$1{,}0\times10^{24}$
256	$2{,}8\times10^{38}$

→ À l'heure actuelle, on considère, en général, qu'il faut prendre une taille de résumé d'au moins 256 bits pour obtenir un niveau de sécurité correct.

Bien sûr, ceci est en perpétuelle évolution !

Le hachage cryptographique implique des calculs qui ne peuvent pas être inversés. Ces fonctions ont des propriétés spéciales qui les rendent utiles pour les signatures numériques et d'autres formes d'authentification.

Quel est l'utilisation la plus courante des fonctions des hachages ?

Le stockage de mots de passe dans une base de données.

En effet, les fonctions de hachage nous permettent de **garder nos mots de passe en sécurité pendant le stockage**.

Grâce aux fonctions de hachage les bases de données ne stockent pas les mots de passe eux-mêmes mais elles stockent uniquement les valeurs de hachage correspondant aux mots de passe !

Pour illustrer cela, prenons l'exemple de votre compte Facebook !

Des entreprises comme Facebook stockent des milliards de mots de passe d'utilisateurs…

Vous imaginez bien que si ces sociétés conservaient les mots de passe sous forme de texte en clair, tout attaquant qui pourrait pénétrer dans la base de données de mots de passe serait en mesure d'accéder à tous les comptes qu'ils trouvent.

→ Facebook stocke le hachage d'un mot de passe au lieu du mot de passe lui-même !

Que se passe-t-il concrètement lorsque vous vous connectez ?

Lorsque vous entrez votre mot de passe pour vous connecter à votre compte, celui-ci est tout d'abord haché.

Ce hachage est ensuite comparé au hachage de mot de passe stocké dans la base de données.

Si les deux hachages correspondent, le mot de passe correct a été entré et l'utilisateur a accès.

L'avantage est qu'avec cette technique est que si un attaquant pénètre dans la base de données, il ne trouvera que les hachages de mot de passe plutôt que les mots de passe.

→ Cela rend le travail des hackers, qui souhaiteraient accéder à votre compte, beaucoup plus difficile (mais pas impossible !)

Nous venons de voir que le gros avantage des fonctions de hachage c'est qu'elles sont rapides.

Mais il y a également un souci avec ces fonctions de hachage…



Et le souci est justement qu'elles sont rapides !!!

En effet si dans certains cas la rapidité des fonctions de hachage est un gros avantage, notamment pour générer des signatures, dans d'autres cas, comme dans le cas d'une authentification, **la vitesse est un gros désavantage !**

Si l'algorithme est rapide… le crackage est rapide…

HEH be Sciences et technologies

Chapitre 1

<u>Problématique des mots de passe faibles</u>

Beaucoup de personnes ont de très mauvais mots de passe et de plus, les humains ont tendance à penser selon des modèles prévisibles et à choisir des mots de passe faciles à retenir…

→ Ces mots de passe sont vulnérables aux attaques de dictionnaire.

Ces attaques de dictionnaire parcourent des milliers ou des millions de combinaisons de mots de passe les plus courantes chaque seconde, dans le but de trouver le mot de passe correct pour un compte.

Si les hachages de mot de passe sont stockés à la place, les choses sont un peu différentes. Lorsqu'un attaquant rencontre une base de données de hachages de mots de passe, il peut utiliser soit des **tables de hachage** ou **tables arc-en-ciel** pour rechercher des hachages correspondants qu'ils peuvent utiliser pour trouver les mots de passe.

Une **table de hachage** est une liste de hachages pré-calculée pour les mots de passe courants qui est stockée dans une base de données. Ils nécessitent plus de travail à l'avance, mais une fois la table terminée, il est beaucoup plus rapide de rechercher les hachages dans la table que de calculer le hachage pour chaque mot de passe possible.

Un autre avantage est que ces tables peuvent être utilisées à plusieurs reprises.

Les **tables arc-en-ciel** sont similaires aux tables de hachage, sauf qu'elles occupent moins d'espace au prix d'une plus grande puissance de calcul.

Ces deux méthodes d'attaque deviennent beaucoup plus pratiques si des mots de passe faibles sont utilisés.

Si un utilisateur a un mot de passe commun, il est probable que le hachage du mot de passe se trouve dans la table de hachage ou la table arc-en-ciel.

→ Pour complexifier la tâche des hackers, les utilisateurs doivent absolument choisir des mots de passe plus longs et plus complexes, qui sont beaucoup moins susceptibles d'être stockés dans les tableaux.

Mais il existe également une autre solution :

L'utilisation de ce que l'on appelle **le salage**.

Le salage

Qu'est ce que le salage ?

Le salage est essentiellement **l'ajout de données aléatoires avant qu'elles ne soient soumises à une fonction de hachage**

En ajoutant une chaîne de données aléatoire à un mot de passe avant qu'il ne soit haché, cela le rend essentiellement plus complexe, ce qui entrave les chances de réussite de ces attaques.

Prenons un exemple pour comprendre le fonctionnement et l'intérêt du salage en pratique.

Imaginez que votre mot de passe lié à votre compte Facebook soit « 1234 ».

Via une calculatrice en ligne SHA-256, nous obtenons ce qui suit comme valeur de hachage:

03ac674216f3e15c761ee1a5e255f067953623c8b388b4459e13f978d7c846f4

Ce hachage est ce qui serait stocké dans la base de données de votre compte.

Du coup, lorsque vous vous connectez et que vous saisissez votre mot de passe « *1234* », celui-ci est haché puis la valeur est comparée à la valeur stockée dans la base de données.

Étant donné que les deux valeurs sont identiques, vous aurez accès.

Maintenant, si un attaquant fait irruption dans la base de données, il aura accès à cette valeur (ainsi qu'à tous les autres hachages de mot de passe qui s'y trouvent).

L'attaquant prendrait alors cette valeur de hachage et la rechercherait dans sa table de hachage pré-calculée ou sa table arc-en-ciel.

Puisque « *1234* » est l'un des mots de passe les plus courants, il trouverait le hachage correspondant très rapidement.

La table de hachage leur dirait que :
03ac674216f3e15c761ee1a5e255f067953623c8b388b4459e13f978d7c846f4
correspond à :
1234

De cette manière, l'attaquant possèdera votre mot de passe et pourra ensuite l'utiliser pour se connecter à votre compte...

C'est donc là que le salage va devenir intéressant.

Afin de rendre les choses plus difficiles, nous pouvons ajouter un sel de données aléatoires au mot de passe avant qu'il ne soit haché.

→ Ce qui va réduire considérablement les chances que les tables de hachage et les tables arc-en-ciel retournent un résultat positif.

Prenons un sel de 16 caractères de données aléatoires :
H82BV63KG9SBD93B

Ajoutons le à notre mot de passe « *1234* » :
1234H82BV63KG9SBD93B

Si nous le faisons passer par la même fonction de hachage que nous avons utilisé auparavant, elle nous renvoie le haché suivant :
91147f7666dc80ab5902bde8b426aecdb1cbebf8603a58d79182b750c10f1303

Comme vous le voyez, cette valeur de hachage n'est ni plus longue ni plus complexe que la précédente, mais ce n'est pas le but.

Bien qu'ils soient tous deux de la même longueur, "*1234H82BV63KG9SBD93B*« est un mot de passe beaucoup moins courant, il est donc beaucoup moins probable que son hachage soit stocké dans la table de hachage.

Moins un mot de passe doit être stocké dans une table de hachage, moins il est probable qu'une attaque réussisse.

Voilà comment l'utilisation d'un sel contribue à sécuriser les hachages de mot de passe.

Attention néanmoins aux faiblesses potentielles du salage…

Comme pour beaucoup de chose, le salage perd de son efficacité s'il est mal fait...

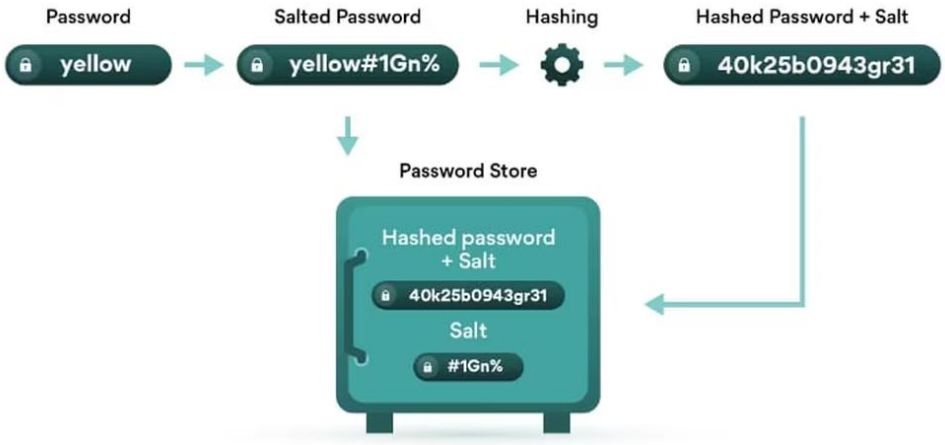
Les deux problèmes les plus courants se produisent lorsque **les sels sont trop courts, ou s'ils ne sont pas uniques pour chaque mot de passe**.

Les sels plus courts sont toujours vulnérables aux attaques de la table arc-en-ciel, car ils ne rendent pas le hachage résultant suffisamment rare.

Si les sels sont réutilisés pour chaque mot de passe haché et que le sel est découvert, il est beaucoup plus simple de comprendre chaque mot de passe dans la base de données.

En plus, l'utilisation du même sel signifie également que toute personne possédant le même mot de passe aura le même hachage.

Chapitre 1



Exemple sans salage :

Pseudo	Mot de Passe	Hash
Camille	123456	7c4da0e2a275e4c7d6b9b4dc374ee0f3
Arthur	123456	7c4da0e2a275e4c7d6b9b4dc374ee0f3

Exemple avec salage :

Pseudo	Mot de Passe	Sel	Hash
Camille	123456	a1b2c3	2a509b87f9cc3c207d01abf05a0d2b25
Arthur	123456	x9y8z7	ae5c1c1949c15c0dbf8b109c3c447e1a

Chapitre 1

Fonctions de hashage utilisant du salage

Il n'est pas recommandé d'utiliser des fonctions de hachage normales pour stocker les mots de passe.

Certains ont été conçues avec des fonctionnalités spécifiques qui contribuent à renforcer la sécurité.

Bcrypt

Bcrypt a été développé en 1999 et est basé sur l'algorithme *Blowfish*.

Il est l'un des algorithmes les plus couramment utilisés dans le hachage de mot de passe depuis de nombreuses années.

Il est conçu de façon à être intentionnellement lent, en augmentant le nombre de passage dans la fonction (work factor).

https://laconsole.dev/blog/hachage-work-factor

Argon2

Argon2 a remporté le concours de hachage de mot de passe 2015. C'est encore relativement nouveau en ce qui concerne les algorithmes, mais il est rapidement devenu l'une des fonctions les plus fiables pour hacher les mots de passe.

Argon2 est plus flexible que les autres algorithmes de hachage de mot de passe et peut être implémenté de différentes manières.



Time it takes a hacker to crack your password 2026

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	46 mins	2 hours	3 hours
6	Instantly	37 mins	2 days	5 days	1 week
7	Instantly	16 hours	3 months	10 months	2 years
8	Instantly	2 weeks	12 years	50 years	132 years
9	2 hours	1 year	636 years	3k years	9k years
10	20 hours	32 years	33k years	191k years	645k years
11	1 week	839 years	1m years	11m years	45m years
12	3 months	21k years	88m years	737m years	3bn years
13	2 years	567k years	4bn years	45bn years	221bn years
14	23 years	14m years	241bn years	2tn years	15tn years
15	229 years	383m years	12tn years	175tn years	1qd years
16	2k years	9bn years	653tn years	10qd years	75qd years
17	22k years	259bn years	33qd years	675qd years	5qn years
18	228k years	6tn years	1qn years	41qn years	372qn years

Hive Systems

Read more and download at hivesystems.com/password

https://www.hivesystems.com/blog/are-your-passwords-in-the-green

La cryptographie

Qu'est ce que la cryptographie ?

La cryptographie ou chiffrement, c'est l'**art de chiffrer**, coder les messages. La cryptographie étant un sujet très vaste et existant depuis de très nombreuses années, nous allons uniquement nous focaliser sur les méthodes dites modernes.

Attention aux termes employés puisqu'il ne faut pas confondre *cryptologie* et *cryptographie* !

La **cryptologie** est la "science du secret", et regroupe deux branches : d'une part, la **cryptographie**, qui permet de ***coder les messages***, et d'autre part, la **cryptanalyse**, qui permet de les ***décoder*.**

Il existe deux moyens de faire de la cryptographie :

- la cryptographie à clé secrète (ou privée) ou chiffrement symétrique
- la cryptographie à clé publique ou chiffrement asymétrique

HEH be Sciences et technologies

Chapitre 1

La cryptographie à clé secrète

Les **chiffrements symétriques** sont les héritiers des méthodes anciennes des cryptographies (comme les substitutions, les transpositions,…).

Dans ce type de chiffrement, l'expéditeur et le destinataire disposent chacun d'un algorithme leur permettant respectivement de chiffrer et de déchiffrer un message.

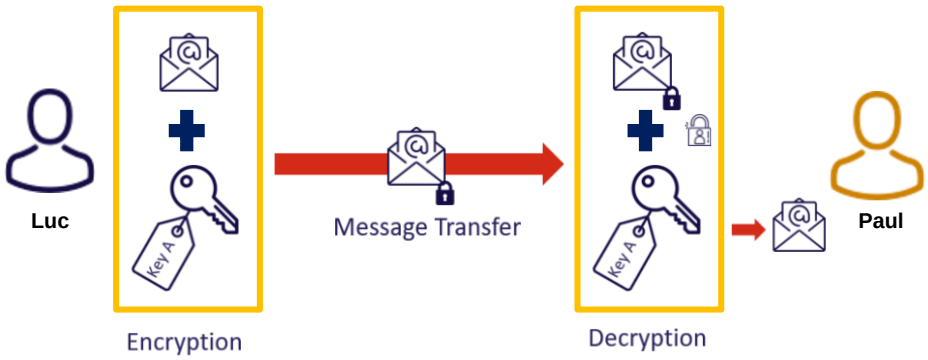
Ces algorithmes sont l'inverse l'un de l'autre (→ le terme symétrique).
Ils dépendent d'une *clé* que doivent s'échanger expéditeur et destinataire.

Dans ce cas-ci, **c'est donc la même clé qui sert au chiffrement et au déchiffrement** !

En particulier, expéditeur et destinataire doivent s'échanger cette clé, qui doit rester secrète sous peine qu'un tiers parvienne à déchiffrer les correspondances.

Voilà pourquoi on parle aussi de *chiffrement à clé secrète*. L'échange des clés secrètes, qui doit se faire par un canal sécurisé, est souvent le point faible de ces méthodes de chiffrement.

Le chiffrement symétrique



Exemples d'utilisation du chiffrement symétrique

Messagerie sécurisée: Le chiffrement symétrique est couramment utilisé dans les applications de messagerie pour protéger la confidentialité des échanges entre utilisateurs. La même clé est utilisée pour crypter et décrypter les messages de données, ce qui garantit que seul le destinataire prévu peut accéder à l'information.

Chiffrement des fichiers: Lorsque vous chiffrez un fichier sur votre ordinateur ou dans le nuage, il utilise souvent des algorithmes de chiffrement symétrique, ce qui garantit que seules les personnes possédant la bonne clé peuvent y accéder.

Réseaux privés virtuels (VPN): Le chiffrement symétrique est utilisé dans les VPN pour créer une connexion sécurisée entre l'appareil d'un utilisateur et un serveur distant. De cette manière, les données circulent en toute sécurité sur l'internet.

Secure Socket Layer (SSL)/Transport Layer Security (TLS): Le cryptage symétrique est utilisé dans les protocoles SSL/TLS pour sécuriser les transactions en ligne, telles que les paiements par carte de crédit et les opérations bancaires en ligne. Il garantit que les informations sensibles sont transmises en toute sécurité entre le navigateur de l'utilisateur et le serveur.

Data Encryption Standard

Le DES (« Data Encryption Standard ») apparu dans les années 1970, a été l'algorithme de chiffrement le plus utilisé au monde durant le dernier quart du XXiè siècle.

Il utilise un algorithme de chiffrement par bloc de 64 bits, c'est-à-dire que le texte est d'abord découpé en bloc de 64 bits et que l'on applique l'algorithme à chaque bloc.

La clé du DES est une chaîne de 64 bits (succession de 0 et de 1), mais en fait seuls 56 bits servent réellement à définir la clé.

En fait les bits 8,16,24,32,40,48,56,64 sont des bits de parité (=bits de détection d'erreur). Le 8ème bit est fait en sorte que sur les 8 premiers bits, il y ait un nombre impair de 1.
Par exemple, si les 7 premiers bits sont 1010001, le 8ème bit est 0.
Ceci permet d'éviter les erreurs de transmission.

DES permet donc 2^{56} clés possibles, soit environ... 72 millions de milliards de possibilités. Cela peut paraître considérable, mais en fait c'est en fait très insuffisant par rapport à la puissance des ordinateurs modernes.

→ le DES a progressivement été abandonné à la fin des années 1990.

Début des années 2000, **le calcul distribue en utilisant les ordinateurs** des particuliers (distributed.net) associé a Deep Crack a prouve son efficacité en cassant une clé en moins de 24 heures.

HEH be Sciences et technologies

Chapitre 1

3DES

En réponse aux vulnérabilités du DES, les cryptographes ont exploré divers schémas de chiffrement multiples pour améliorer la sécurité. En 1999, l'une des méthodes envisagée est le Triple DES (3DES), qui applique l'algorithme DES trois fois avec deux ou trois clés différentes. La longueur de clé effective de 3DES peut être de 112 ou 168 bits, ce qui rend une attaque par force brute beaucoup plus difficile.

Par exemple, avec 3DES utilisant trois clés différentes, l'espace clé est :
2^{168} ce qui donne environ $3{,}74 \times 10^{50}$

Mieux que DES contre les attaques de force brute mais nécessite des calculs intensifs et est plus lent que les algorithmes modernes comme l'AES…

Advanced Encryption Standard

L'AES (« Advanced Encryption Standard ») apparu au début des années 2000, a remplacé le DES.

Cet algorithme a été choisi parmi plusieurs projets déposés auprès du NIST (« National Institute of Standards and Technology ») et il a ensuite été adopté par la NSA afin de devenir le nouveau standard de chiffrement pour les organisations du gouvernement des États-Unis.

Particularité de cet algorithme ?

Ses deux concepteurs sont belges !



Joan Daemen (à gauche) et Vincent Rijmen (à droite).

L'algorithme de l'AES prend en entrée un bloc de 128 bits (16 octets) et utilise une clé de 128, 192 ou 256 bits.

Chaque bloc subit une séquence de 5 opérations (linéaires et non linéaires).
Ces différentes opérations définissent un « tour ».

Pour une clé de 128, 192 ou 256, AES nécessite respectivement 10, 12 ou 14 tours.

Même avec les ressources informatiques les plus puissantes disponibles aujourd'hui, une attaque par force brute contre AES est considérée comme irréalisable.
Par exemple, une attaque par force brute sur AES-128 nécessiterait des tests 2^{128} clés.
Si un supercalculateur hypothétique pouvait tester 10^{18} clés par seconde, cela prendrait encore environ 10^{13} années pour épuiser l'espace clé.

Les principaux défauts du chiffrement symétrique sont :

- l'expéditeur d'un message doit au préalable communiquer la clé au destinataire par un canal sûr
- l'expéditeur ne peut employer une clé qu'avec un destinataire unique (sinon le message peut être décrypté par plusieurs destinataires)

Principe du chiffrement par blocs

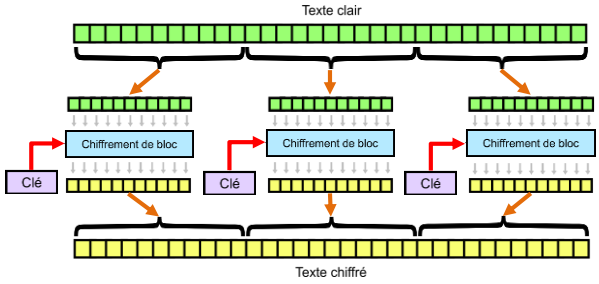
Les chiffrements par blocs ont un principe assez simple :

Le texte initial est fragmenté en blocs de n bits.

Pour chaque bloc *xi* de n bits, l'algorithme de chiffrement est appliqué pour obtenir un bloc chiffré *yi* de même taille.

On remet alors ensembles tous les blocs chiffrés séparément pour obtenir le message chiffré.

Pour le déchiffrement, on fragmente à nouveau le message en blocs de n bits, et pour chaque bloc on applique l'algorithme de déchiffrement.



ChaCha20

Il existe d'autres chiffrements symétriques, **ChaCha20** est un chiffrement de flux conçu en 2008 (par Daniel J. Bernstein) qui utilise une clé de 256 bits.

Contrairement à AES (chiffrement par blocs), il génère un flux pseudo-aléatoire combiné au message en clair par un simple **XOR**.

Il repose uniquement sur des additions, rotations binaires et XOR (opérations **ARX**), sans table de substitution ni multiplication.

Il est particulièrement rapide en pur logiciel, sans nécessiter d'accélération matérielle dédiée (contrairement à AES qui est plus rapide avec des processeurs qui possèdent les instructions **AES-NI**).

Associé à **Poly1305** (ChaCha20-Poly1305, RFC 8439), il forme un mode chiffrement + authentification utilisé par TLS 1.3, WireGuard, OpenSSH et Android.

AES vs ChaCha20

Critères	AES	ChaCha20
Type	Chiffrement par blocs (128 bits)	Chiffrement de flux
Taille de clés	128, 192 ou 256 bits	256 bits
Sans accélération matérielle	Plus lent	Très rapide
Structure interne	Substitution / permutation (S-box)	Addition, rotation, XOR (ARX)
Utilisations courantes	TLS, disques chiffrés, Wi-Fi (WPA2/WPA3)	TLS 1.3, WireGuard, OpenSSH, Android

La cryptographie à clé publique

La **cryptologie asymétrique** (clé publique / clé privée) est basée sur une méthode mathématique garantissant un chiffrement facile et rapide mais un déchiffrement difficile.

A l'inverse de la cryptographie symétrique, cette méthode ne nécessite pas la diffusion préalable de la clé de chiffrement, ce qui fait qu'elle est particulièrement adaptée aux applications utilisant des réseaux (internet entre autres).

En effet c'est seulement la clé publique qui est diffusée et celle-ci n'est utilisée que lors de l'encryptage (clé privée de l'expéditeur + clé publique du destinataire).

Il est donc possible de distribuer librement les clés publiques sur des serveurs de clés.

Ainsi, n'importe qui ayant accès a un serveur de clés peut chiffrer un message pour un destinataire. Il est également démontrable qu'il n'existe aucune méthode permettant de retrouver la clé privée a partir de la clé publique.

Un exemple du fonctionnement de ce type de chiffrement en image ca vous dit ?

Admettons qu'une certaine personne (que nous allons appelé John) doit faire parvenir un message très personnel à une autre personne (Julie par exemple) par la poste.

Mais John n'a pas confiance en son facteur qu'il soupçonne d'ouvrir son courrier. Comment peut-il être sûr de recevoir un message sans qu'il soit lu?

John peut y arriver grâce à la cryptographie à clé publique !



John





Julie

Etape 1 : John va fabriquer des clés : une publique et une privée.

La clé publique va permettre de chiffrer le message (dans le cas de la poste, on symbolisera cela par un cadenas).

La clé privée va permettre de décoder le message (dans notre cas c'est la clé qui ouvre le cadenas).





John







Julie

Etape 2 : John fait parvenir la clé publique (symbolisée ici le cadenas) à Julie.

Il garde bien entendu la clé privée (c-à-d la clé permettant d'ouvrir le cadenas) pour lui.





John







Julie

Etape 3 : Julie chiffre son message destiné à John à l'aide de la clé publique (le cadenas) et lui envoie.

(Julie met son message dans une boite et la ferme à l'aide du cadenas envoyé par John et puis elle lui envoie)





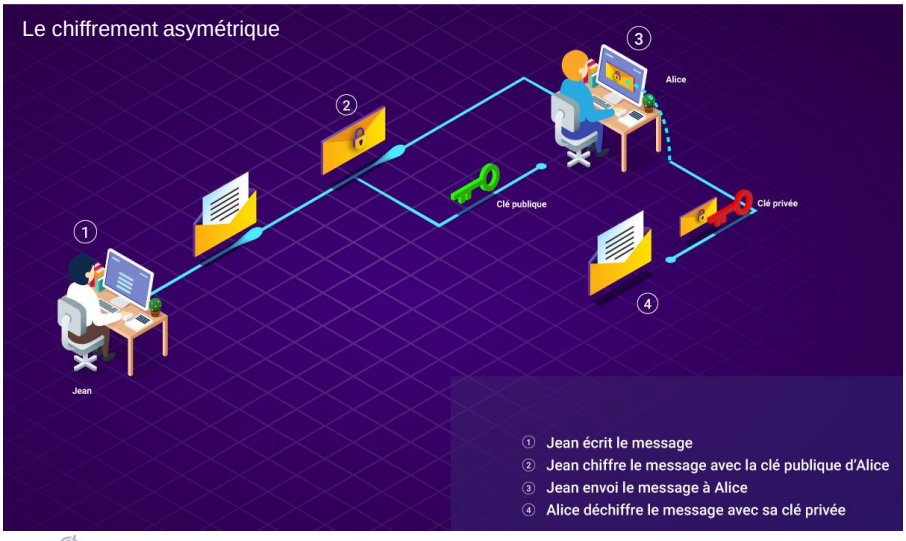


John **Julie**





Etape 4 : John récupère le message envoyé par Julie et le déchiffre à l'aide de sa clé privée (la clé). Etant le seul à posséder la clé, lui seul est en mesure de déchiffrer le message (ouvrir le cadenas).



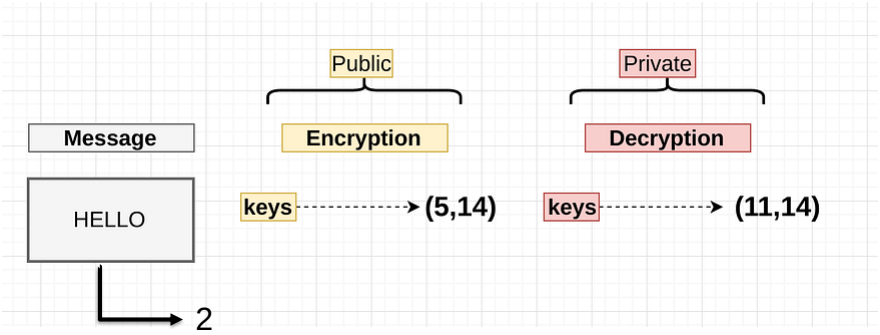
La meilleure cryptographie asymétrique et la plus utilisée à ce jour est la cryptographie **RSA**. Le RSA, dont le nom provient D. **R**ivest, A. **S**hamir et L. **A**dleman, repose sur le principe suivant :

- il est facile de fabriquer de grands nombres premiers *p* et *q* (pour fixer les idées, 500 chiffres).
- étant donné un nombre entier *n=pq* produit de 2 grands nombres premiers, il est très difficile de retrouver les facteurs *p* et *q*.

La donnée *n* est la clé publique : elle suffit pour chiffrer.
Pour déchiffrer, il faut connaitre *p* et *q*, qui constituent la clé privée.

Le problème de factorisation de grands entiers étant très difficile, la connaissance de la clé publique *n* ne permet pas de retrouver les entiers *p* et *q*, qui constituent la clé secrète.

Fonctionnement de RSA :



Admettons qu'on veuille envoyer un message « Hello ». Ce message va d'abord être converti en chiffre pour pouvoir lui appliquer des opérations arithmétiques.

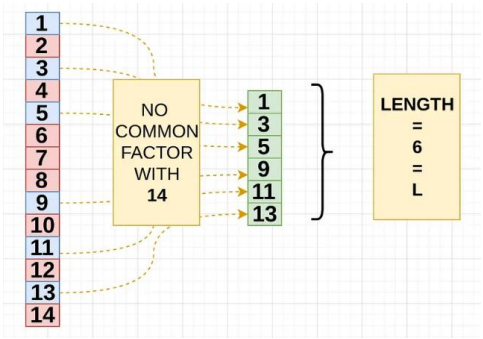
Dans cet exemple, « Hello » sera converti en valeur « 2 ».

Au niveau du choix des clés de chiffrement et de déchiffrement, il faut créer des clés dont les éléments de base sont des nombres premiers !

Dans cet exemple, on a choisi deux nombres premiers **P = 2** et **Q = 7**.

A partir de là on a donc notre nombre entier **N = P * Q = 2 * 7 = 14**. Ce nombre correspondra à notre ***modulo***.

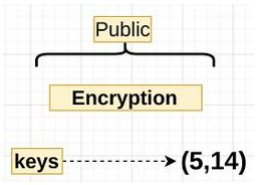
Après on a besoin de connaitre la valeur **L** qui est le nombre d'entiers entre 1 et N qui sont premiers avec N.



Un moyen rapide de trouver la valeur L (en connaissant P et Q) est :

```
( Q - 1 ) * ( P - 1) = L
(7 - 1 ) * ( 2 -1 ) = 6
```


Dans notre exemple on voit que la clé de chiffrement est (5,14).



Cette clé de chiffrement doit respecter quelques règles :

- Elle doit être comprise strictement entre **1** et la valeur **L**.
- 1 < E < L
- Elle doit être première avec **L**, le chiffre ne doit donc pas de diviseurs communs avec **L**.

Concernant la première règle, toutes les valeurs entre 1 et L (6) sont [2,3,4,5]

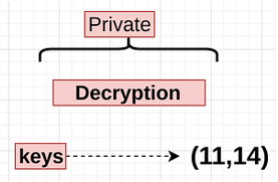
Elle doit être première avec L (6).

→ La seule possibilité est 5 (que l'on symbolisera par E).

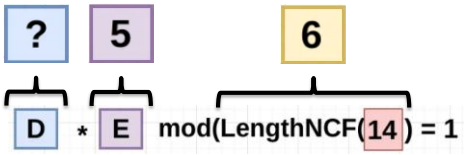
→ Notre clé de chiffrement est (5,14)

Chapitre 1

Dans notre exemple on voit que la clé de déchiffrement est (11,14).



Cette clé de déchiffrement doit respecter une règle :

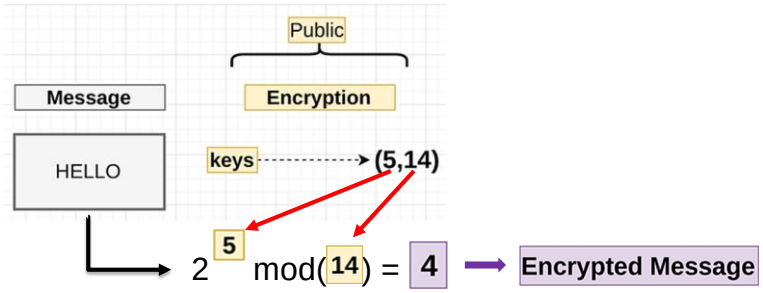


Ce qui donne que D = 11 dans notre exemple puisque :

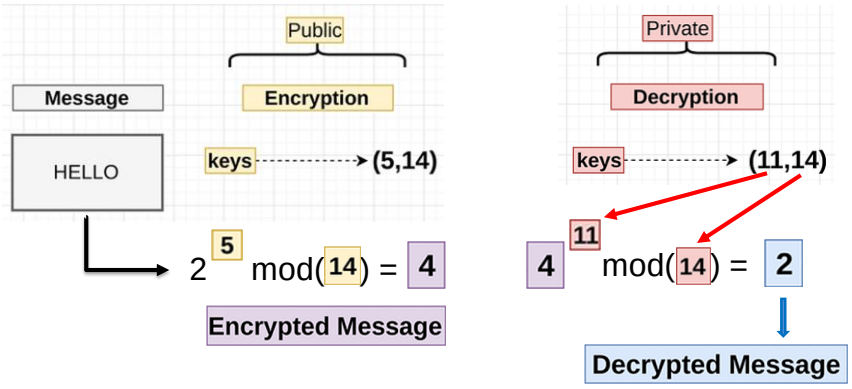
```
D * E % LNCF(N) = 1
11 * 5 % 6 = 1
```

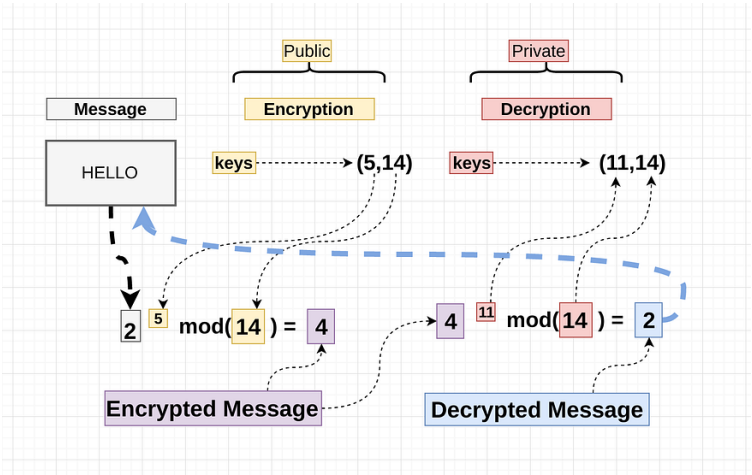

Chapitre 1

Finalement, avec notre clé publique, on peut chiffrer le message.



Et avec notre clé privée, on peut déchiffrer le message reçu.





Pourquoi on ne peut pas retrouver la clé privée avec de très grands nombres premiers ?

En pratique, P et Q ont environ 309 chiffres chacun (1024 bits). N a alors environ 617 chiffres. Par exemple, une clé que j'ai générée commence par 14723083482141639082178042220915564919 3… et continue sur près de 600 chiffres.

Deviner P au hasard ne marche pas. Il existe environ **10^{305} nombres premiers** de cette taille. Pour comparer, l'univers observable contient environ 10^{80} atomes. La probabilité de tomber sur le bon P est d'environ 1 sur 10^{305} : en pratique, nulle.

Les essayer un par un ne marche pas non plus. À mille milliards d'essais par seconde, il faudrait environ **10^{285} années**. L'âge de l'univers est d'environ $1{,}4 \times 10^{10}$ années.

Pour être rigoureux : ce n'est pas *mathématiquement impossible*, c'est *impossible en pratique* avec les ordinateurs et les algorithmes connus. Un ordinateur quantique assez puissant pourrait le faire grâce à l'algorithme de Shor. C'est pour ça qu'on prépare déjà une cryptographie « post-quantique ».

HEH be Sciences et technologies

Chapitre 1

L'avantage principal propre au chiffrement asymétrique est que la problématique de la communication de la clé de déchiffrement n'existe plus, dans la mesure ou les clés publiques peuvent être envoyées librement.

Le chiffrement par clés publiques permet donc a des personnes d'échanger des messages chiffres sans pour autant posséder de secret en commun.

Le problème principal que pose le **RSA est sa lenteur : il est de 1000 a 10000 fois plus lent** que le **DES.**

→ **La transmission de gros fichiers est donc particulièrement lente,** ce qui n'est guère pratique.

Le second problème est qu'il n'est **pas aussi sûr que l'AES : les algorithmes de factorisation** sont de plus en plus performants et il est nécessaire d'employer des nombres premiers de plus en plus longs.

On est certain d'avoir un chiffrage inviolable avec des nombres premiers très grands. Cependant plus la clé est longue, plus le chiffrage et le déchiffrage sont longs, ce qui fait que l'on a intérêt a chiffrer des messages assez courts.

Le chiffrement hybride

Comme nous venons de le voir, le chiffrement asymétrique résout le problème de l'échange de clé, mais il est très **lent** (1000 à 10000 fois plus lent que le symétrique).

À l'inverse, le chiffrement symétrique est rapide, mais nécessite un canal sécurisé pour échanger au préalable la clé secrète entre les deux parties.

Le **chiffrement hybride** combine ces deux méthodes afin de profiter des avantages de chacune, sans leurs inconvénients.

Le principe : utiliser l'asymétrique uniquement pour échanger une clé secrète temporaire, appelée **clé de session**.

Cette clé de session sert ensuite à chiffrer, en symétrique donc rapidement, toutes les données échangées durant la communication.

Étapes du chiffrement hybride

Étape 1 : l'expéditeur génère une clé secrète aléatoire (clé de session) pour chiffrer les données à transmettre en symétrique.

Étape 2 : l'expéditeur chiffre cette clé de session avec la clé publique du destinataire (chiffrement asymétrique).

Étape 3 : il envoie au destinataire la clé de session chiffrée, ainsi que les données chiffrées symétriquement avec cette même clé.

Étape 4 : le destinataire déchiffre la clé de session avec sa clé privée, puis l'utilise pour déchiffrer les données reçues.

→ C'est exactement ce principe qu'utilise le protocole **SSL/TLS (HTTPS)**, que nous verrons plus loin dans ce chapitre !

Et au niveau du WiFi ?

En matière de Wi-Fi, les données qui transitent entre deux machines d'un même réseau sont chiffrées à l'aide d'un des protocoles WEP, WPA ou WPA2.

Ces protocoles (du plus ancien au plus récent) utilisent des algorithmes de chiffrement différents et en particulier des clés de tailles différentes.

WEP

Le protocole WEP (Wired Equivalent Privacy ou Protection Equivalente au Câble) utilise une clé d'une longueur de 64 à 256 bits dont 24 ne sont pas utilisés pour le chiffrement. Ce protocole utilise une méthode de chiffrement par flot.

Le **chiffrement par flot** est une des deux grandes catégories de chiffrements modernes en cryptographie symétrique, l'autre étant le chiffrement par bloc. Un chiffrement par flot arrive a traiter les données de longueur quelconque et n'a pas besoin de les découper.

L'algorithme utilisé par le chiffrement par flot du protocole WEP est le RC4. Il s'agit d'un algorithme concu en 1987 par Ronald Rivest, l'un des inventeurs du RSA. Officiellement nomme *Rivest Cipher 4,* l'acronyme *RC est aussi surnomme Ron's Code.*

Le principe du WEP consiste à définir dans un premier temps une clé secrète de 40 ou 128 bits. Cette clé secrète doit être déclarée au niveau du point d'accès et des clients.

La clé sert à créer un nombre pseudo-aléatoire d'une longueur égale à la longueur de la trame.

Chaque transmission de données est ainsi chiffrée en utilisant le nombre pseudo-aléatoire comme masque grâce à un *OU Exclusif* entre le nombre pseudo-aléatoire et la trame.

De par sa popularité, RC4 a fait l'objet de nombreuses recherches. Il est désormais considéré comme peu sûr du point de vue cryptographique et ne devrait pas être employé pour de nouvelles applications.

Dans le cas du WEP, un vecteur d'initialisation de 24 bits est utilisé, ce qui permet de produire environ 16,8 millions clés supplémentaires à partir d'une clé principale.
Ce nombre est largement insuffisant eu égard aux possibilités de l'attaque.

WPA/WPA2

WPA (*WiFi Protected Access)* est une solution de sécurisation de réseau WiFi proposé par la WiFi Alliance, afin de combler les lacunes du WEP.

Le WPA repose sur des protocoles d'authentification et un algorithme de cryptage robuste : **TKIP** (*Temporary Key Integrity Protocol*).

Le protocole TKIP permet la génération aléatoire de clés et offre la possibilité de modifier la clé de chiffrement plusieurs fois par secondes, pour plus de sécurité.

Le fonctionnement de WPA repose sur la mise en œuvre d'un serveur d'authentification (la plupart du temps un serveur RADIUS), permettant d'identifier les utilisateurs sur le réseau et de définir leurs droits d'accès.

Néanmoins, il est possible pour les petits réseaux de mettre en œuvre une version restreinte du WPA, appelée *WPA-PSK* (pour Pre-Shared Key), en déployant une même clé de chiffrement dans l'ensemble des équipements, ce qui évite la mise en place d'un serveur RADIUS.

HEH be Sciences et technologies

Chapitre 1

Le **WPA2**, également connu sous le nom IEEE 802.11i et apparu en 2004, est le successeur de WPA. Contrairement au WPA qui utilise l'algorithme TKIP, le WPA2 utilise l'algorithme CCMP, qui s'appuie quant à lui sur l'AES et qui est plus fort que TKIP.

La compatibilité WPA2 est obligatoire pour les équipements certifiés Wi-Fi depuis 2006.

Et le WPA3 ?

Le protocole WPA3 a été introduit par la Wi-Fi Alliance début 2018 et la prise en charge du WPA3 est obligatoire pour les appareils portant le logo « Wi-Fi CERTIFIED™ » depuis juillet 2020.

Quels sont les changements apportés par le WPA3 ?

Déjà, il va exister 2 versions différentes du WPA3 :
- Le WPA3-Personal
- Le WPA3-Enterprise

WPA3-Personal

La classique authentification WPA2-PSK sera remplacée par WPA3-SAE (*Simulaneous Authentication of Equals*). Ce nouveau standard utilisera une clé de chiffrement de 128 bits ainsi que le protocole Forward Secrecy qui a pour but de résister aux attaques hors-ligne par dictionnaire tout en améliorant la sécurité lors de l'échange de clé.

WPA3-Enterprise

Côté entreprise, on passe à un chiffrement basé sur une clé de 192 bits et utilisera un vecteur d'initialisation de 48 bits comme le demande les organisations sensibles ou les gouvernements afin de garantir un niveau de sécurité minimal.

En plus de cela, WPA3 vise également à simplifier le processus de connexion (qu'ils ont baptisé *« Easy Connect »*) des équipements n'ayant pas forcément d'interface visuelle de configuration. Avec l'explosion de l'IOT et la modernisation du matériel industriel cette amélioration est la bienvenue dans les entreprises.



Les certificats et la signature numérique

La signature numérique (ou signature électronique) d'un document utilise à la fois la *cryptographie asymétrique* et les *fonctions de hachage*.

C'est en effet par l'association de ces deux techniques que nous pouvons obtenir les 5 caractéristiques d'une signature (authentique, infalsifiable, non réutilisable, inaltérable, irrévocable).

- **authentique** : l'identité du signataire doit pouvoir être retrouvée de manière certaine.
- **infalsifiable** : la signature ne peut pas être falsifiée (quelqu'un ne peut se faire passer pour un autre).
- **non réutilisable** : la signature n'est pas réutilisable (elle fait partie intégrante du document signé).
- **inaltérable** : un document signé est inaltérable. Une fois qu'il est signé, on ne peut plus le modifier.
- **irrévocable** : la personne qui a signé ne peut le nier.

Principe de fonctionnement :

Prenons l'exemple de M. Mandoux qui veut envoyer un message à M. Petein.

Au départ, M. Mandoux va devoir choisir une fonction de chiffrement (avec la fonction de déchiffrement qui lui est associée) et une fonction de hachage.

En fonction du chiffrement choisi, M. Mandoux va générer une clé privée et une clé publique.

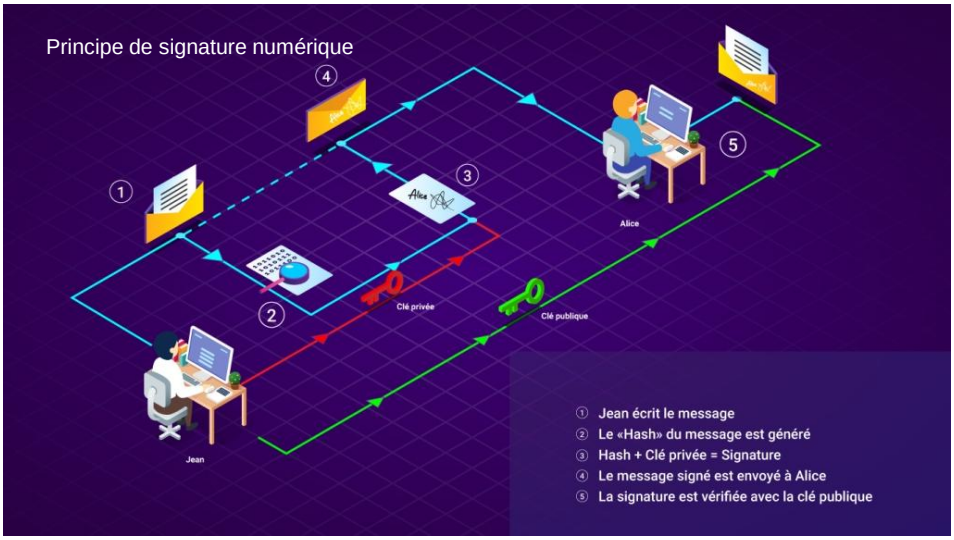
Cette clé publique il devra la transmettre à M. Petein via un canal non sécurisé puisque celle-ci ne doit pas être secrète.

Maintenant M. Mandoux va devoir préparer son message signé !

Tout d'abord, à partir des données qu'il veut transmettre, il va produire un condensat du message à l'aide de la fonction de hachage choisie.

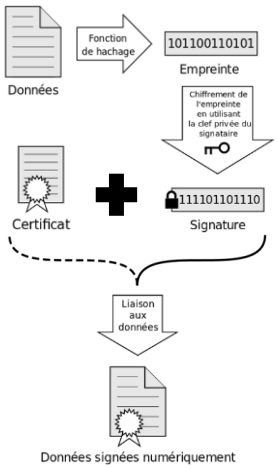
Une fois ce condensat obtenu, il va chiffrer celui-ci à l'aide de sa clé privée.

→ Le résultat obtenu sera ce qu'on appelle *la signature du message*.



Il ne reste plus à M. Mandoux que de préparer le message signé à envoyer à M. Petein. Pour cela il suffit de regrouper le message que l'on souhaite transmettre et la signature dans un même conteneur.

En résumé :



Maintenant M. Petein reçoit le message signé de M. Mandoux.

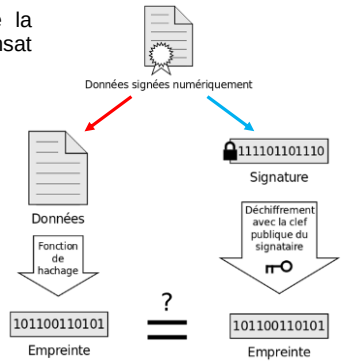
Il va donc devoir vérifier que c'est bien celui-ci qui a envoyé le message reçu.

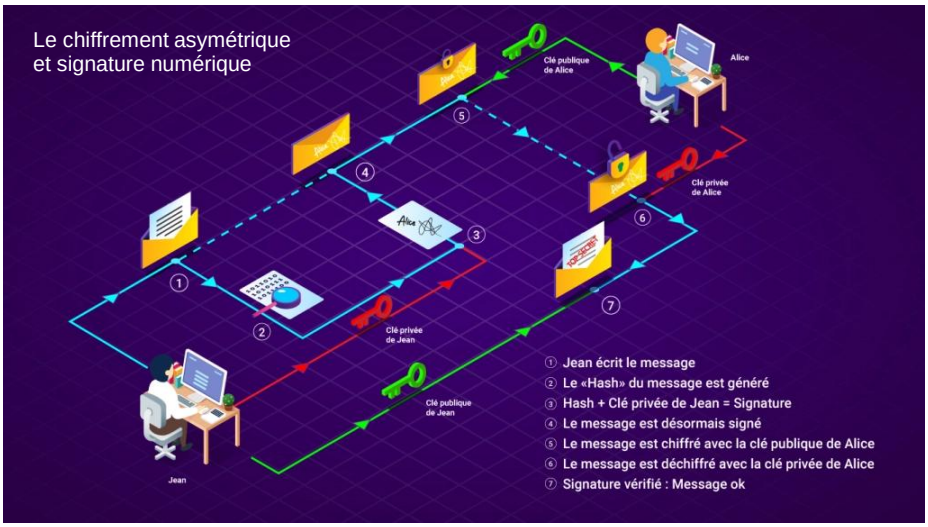
Pour ce faire M. Petein va devoir, à l'aide de la fonction de hachage convenue, produire un condensat du message reçu.

Ensuite il va devoir déchiffrer la signature, grâce à la clé publique préalablement transmise.

Finalement il va comparer les deux empreintes obtenues.

Si celles-ci sont identiques, alors le message est authentifié !





Limites et vulnérabilités

Théoriquement, la résistance de ce genre de dispositif dépendra essentiellement de la force du chiffrement asymétrique choisi ainsi que de la taille des clés choisies.

Pratiquement, la signature numérique reste soumise au problème de diffusion de la clé publique…

La signature numérique est considéré comme une *authentification faible* car elle s'appuie sur une seul facteur d'authentification (dans ce cas la clé privée).

→ Si, pour une raison quelconque, la clé privée est compromise, n'importe qui la possédant pourra produire des messages frauduleux qui seront complètement indiscernables des messages légitimes…

Solutions ?

- ✓ Pour la diffusion des clés publiques, il est conseillé de passer par une infrastructure à clés publiques.
- ✓ Pour l'authentification, il est recommandé de mettre en place une *authentification forte*.

L'authentification forte

L'authentification simple (ou authentification faible) utilise un seul facteur d'authentification (tel qu'un mot de passe). Cela peut être suffisant dans certains cas mais bien entendu lorsqu'on parle de sécurité avancée cela s'avère largement insuffisant.

Le principe de l'authentification forte est d'utiliser plusieurs facteurs de nature distincte afin de rendre la tâche plus compliquée à un éventuel attaquant.
Les facteurs d'authentification peuvent être classés comme suit :

- **Quelque chose que l'on sait** : le mot de passe en est le meilleur exemple.
- **Quelque chose que l'on possède** : comme une clé, une carte magnétique, un token,...
- **Quelque chose que l'on est** : comme une empreinte digitale, une distribution veineuse ou de votre iris.

L'authentification forte consiste à combiner au moins 2 de ces facteurs d'authentification.

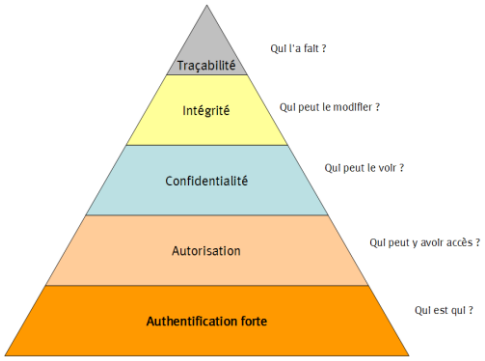
Quelques exemples d'authentification forte :

- un mot de passe et une carte comme pour vos retraits aux guichets automatiques de billets avec un code PIN et une carte munie d'une puce électronique.
- un mot de passe et un code SMS pour vos sessions e-Banking (vous possédez le mobile en plus du mot de passe).
- un mot de passe et une empreinte digitale pour un accès à une zone physique très protégée dans une entreprise par exemple.

Quels sont les avantages d'une authentification forte ?

L'authentification forte est une des fondations essentielles permettant de garantir :

- L'autorisation
- La confidentialité
- L'intégrité
- La traçabilité



Chapitre 1

Finalement, on peut répertorier différentes familles de technologies pour l'authentification forte est :

- Le *One Time Password* (OTP) ou mot de passe à usage unique.

L'authentification OTP constitue pour les entreprises un moyen simple d'authentifier des utilisateurs pour leur fournir un accès adéquat. Pour accéder à un réseau, à des ressources informatiques, à une application basée dans le cloud,…

Exemple d'utilisation :

Vous travaillez dans une banque et vous faites du télétravail. Afin de vous connecter de manière sécurisée, il vous faudra toujours saisir un nom d'utilisateur et un mot de passe à l'écran, puis il faudra encore saisir le mot de passe à usage unique, et c'est seulement après la saisie de ce trio gagnant que l'accès sera autorisé.

Comment le serveur d'authentification peut-il connaître tous les mots de passe ?

Chaque générateur de mot de passe comporte un numéro de série électronique, et ce numéro de série électronique est lié à une formule mathématique qui est connue par le générateur de mot de passe et par le serveur.

Il s'agit de faire générer automatiquement des mots de passe (généralement de 6-8 chiffres ou caractères) par un petit appareil dédier à cet usage. Chaque minute environ, un nouveau mot de passe est affiché, et si il est utilisé, ce mot de passe ne pourra plus être utilisé une seconde fois, même dans la seconde qui suit.

Au niveau des générateurs de mots de passe à usage unique, ils existent sous différentes formes :

- Soit via SMS

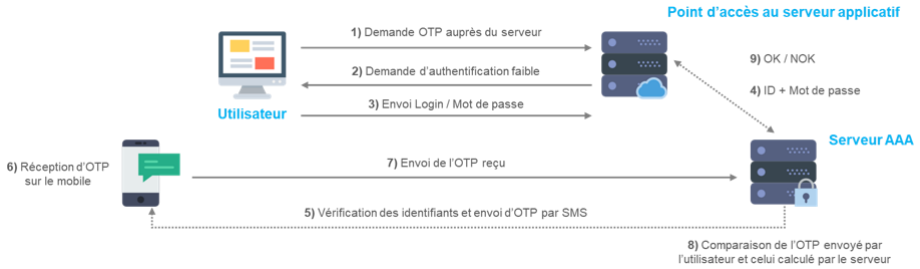
- Soit via soft token (applications smartphone)

- Soit via hard token (keychain token ou calculette bancaire par exemple)

<u>OTP par SMS</u>

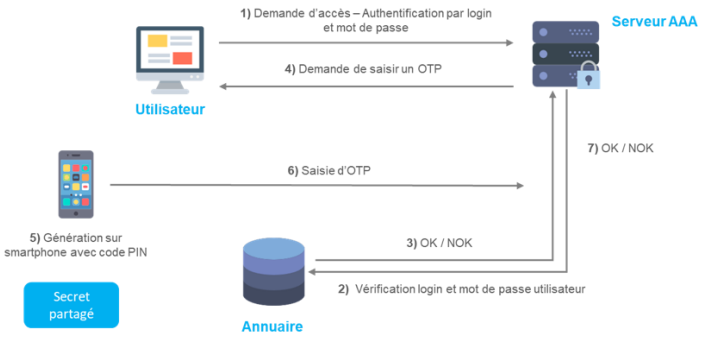
Ce mécanisme consiste à recevoir par SMS un mot de passe à usage unique (utilisable pour une durée déterminée) qui sera renseigné lors du processus d'authentification.

Ce mécanisme est utilisé par de très nombreux établissements bancaires, notamment lors de la réalisation d'achats sur internet.



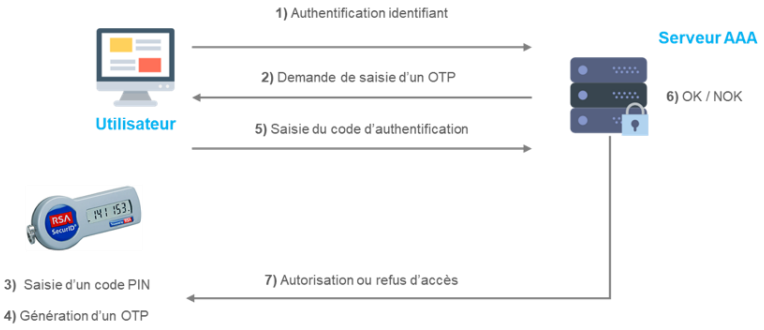
OTP via soft token

Ce mécanisme consiste à générer un mot de passe unique via une application sur son smartphone. Il nécessite donc que l'utilisateur installe sur son smartphone l'application contenant le soft token (il peut s'agir directement de l'application de la banque en question).



OTP via hard token

Ce mécanisme consiste à générer un mot de passe unique via une application sur son smartphone. Il nécessite donc que l'utilisateur installe sur son smartphone l'application contenant le soft token (il peut s'agir directement de l'application de la banque en question).









Chapitre 1

La deuxième grande famille de technologies pour l'authentification forte est :

- L'inhérence ou la biométrie.

Qu'est-ce que la biométrie ?

La biométrie est la vérification de l'identité d'un individu par ce qu'il est, c'est-à-dire en utilisant des caractéristiques physiques (ou comportementales).

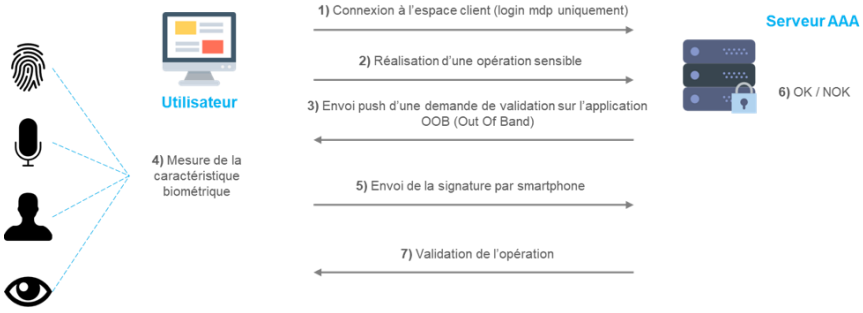
Il faut savoir que la aussi il existe plusieurs grandes familles de techniques de reconnaissance biométrique : la reconnaissance de l'empreinte digitale, du réseau veineux du doigt, de l'iris, de la voix et de la forme du visage,…

Fonctionnement :

L'utilisateur se soumet alors à une première phase – l'enrôlement – où il présente à l'autorité en charge de l'enrôlement une ou plusieurs données biométriques qui est modélisée puis stockée comme référence.

La seconde phase consiste à s'authentifier, en présentant son empreinte biométrique qui sera comparée à celle référencée.

Diagramme de fonctionnement :



A l'avenir, afin d'augmenter encore la sécurité, on utilisera sûrement de la biométrie multimodale, qui est une association de plusieurs données biométriques.

Chapitre 1

La troisième et dernière grande famille de technologies pour l'authentification forte est l'utilisation de :

- Certificats numériques ou certificats électroniques .

Un certificat numérique est identique à une carte d'identité numérique. Dans ce cas, il signé par un tiers de confiance (comme une Autorité de Certification) qui atteste du lien entre l'identité physique et l'entité numérique.

Les standards les plus utilisés pour la création des certificats numériques sont le X.509 (défini dans la RFC 5280) ou OpenPGP (défini dans la RFC 4880).

La différence notable entre ces deux formats est qu'un **certificat X.509** ne peut contenir qu'*un seul identifiant*, que cet identifiant doit contenir de nombreux champs prédéfinis, et ne peut être signé que par une seule autorité de certification.
Un **certificat OpenPGP** peut contenir *plusieurs identifiants*, lesquels autorisent une certaine souplesse sur leur contenu, et peuvent être signés par une multitude d'autres certificats OpenPGP.

Les clés de sécurité (FIDO2)



Le standard **FIDO2** permet de s'authentifier sans mot de passe, via une clé de sécurité physique (ex. YubiKey) ou un capteur biométrique.

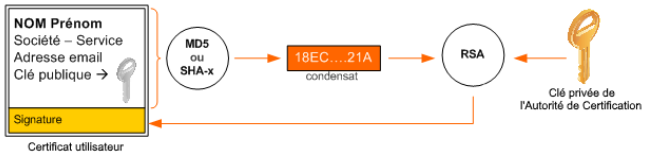
Il repose sur la **cryptographie asymétrique** : l'appareil génère une paire de clés propre à chaque service ; la clé privée ne le quitte jamais.

À chaque connexion, le service envoie un **défi** que l'appareil signe avec la clé privée ; le service vérifie avec la clé publique du compte.

Cette méthode est très robuste : elle élimine le risque de vol par hameçonnage (**phishing**), la clé privée ne pouvant être copiée.

De nombreux services (Google, Microsoft, GitHub…) proposent la norme **WebAuthn**, l'implémentation de FIDO2 dans les navigateurs web.

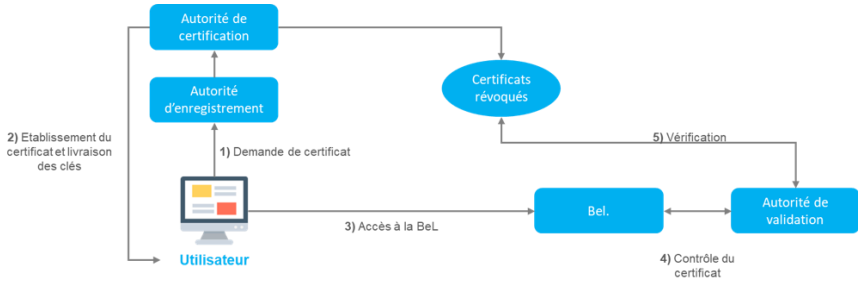
Création d'un certificat utilisateur :



Les *Autorités de Certification* (AC) sont des organismes enregistrés et certifiés auprès d'autorités publiques et/ou de gouvernance de l'Internet qui établissent leur viabilité comme intermédiaire fiable.

Exemples d'Autorités de Certification (AC) accrédités et utilisés en Belgique :
- **Isabel** (notamment utilisé par des banques comme Belfius, BNP Paribas Fortis, ING, KBC,…)
- **GlobalSign** (utilisé par la BBC, airBNB, Adobe, Microsoft,…)
- **Certipost** (utilisé par le SPF Finances)
- **QuoVadis** (utilisé par le SPF Economie)

Diagramme du fonctionnement via certificats :



Exemple avec une demande d'accès à une banque en ligne (Bel)

Les certificats peuvent être stockés par des serveurs de clés, qui peuvent aussi faire office d'autorité d'enregistrement et de certification.

Ils recensent et contrôlent les certificats. Ils possèdent souvent une liste des certificats révoqués.

Chapitre 1

Les services des Autorités de Certification sont principalement utilisés dans le cadre de la sécurisation des communications numériques via le protocole *Secure Socket Layer* (**SSL**) ou le protocole *Transport Layer Security* (**TLS**), qui est l'évolution de SSL.

Ces protocoles sont utilisés par exemple pour sécuriser les communications web (protocole HTTPS) ou email (SMTP, POP3, IMAP... sur TLS), ainsi que pour la sécurisation des documents numériques (par exemple au moyen de signatures électroniques avancées telles que *PAdES* pour des documents PDF).

Un certificat SSL est un fichier de données qui lie une clé cryptographique aux informations d'une organisation ou d'un individu.

Installé sur un serveur, le certificat permet d'assurer une connexion sécurisée entre le serveur web et le navigateur.

Généralement, SSL est utilisé pour sécuriser les transactions bancaires, le transfert de données et les informations de connexions, telles que les noms d'utilisateur et les mots de passe,…

Les certificats SSL lient ensemble :

- Un nom de domaine, un nom de serveur et un nom d'hôte.
- L'identité de l'organisation (nom d'entreprise) et le lieu.

L'organisation doit installer le certificat SSL sur son serveur web afin d'initialiser des sessions sécurisées avec les navigateurs.

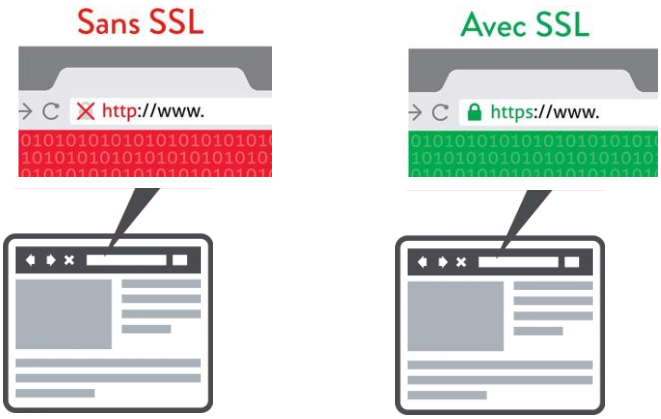
L'organisation devra se soumettre à une vérification auprès de l'Autorité de Certification, dont le degré va varier selon le type de certificat SSL pour lequel elle a effectué une demande.

Une fois le certificat SSL installé sur un site, les visiteurs pourront accéder à celui-ci à travers une connexion « HTTPS » qui indique au serveur qu'il doit établir une connexion sécurisée avec le navigateur.

Lorsque la connexion sécurisée est établie, l'ensemble du trafic entre le serveur et le navigateur sera sécurisé.

Comment savoir si la connexion client-serveur est sécurisée ?

Simplement en observant la barre de navigation de votre navigateur internet !



Chapitre 1

Au niveau des types de certificats SSL, il existe 3 grandes familles :

1. certificat à validation étendue (EV) : niveau de chiffrement le plus élevé
Pour obtenir ce certificat, les instances émettrices demandent une grande quantité d'informations. → les visiteurs obtiennent l'assurance que votre site web est exploité par votre entreprise et que les connexions à ce domaine sont sécurisées.

2. certificat à validation d'organisation (OV) : niveau de chiffrement moyen
Le certificat OV comporte lui aussi une authentification de votre entreprise. Pour obtenir ce certificat, le fournisseur en question vérifie les données que vous mettez à sa disposition. Mais vos informations ne sont pas mises en avant comme pour le certificat EV qui est plus étendu. Si les visiteurs souhaitent accéder à ces données, ils devront les consulter les séparément.

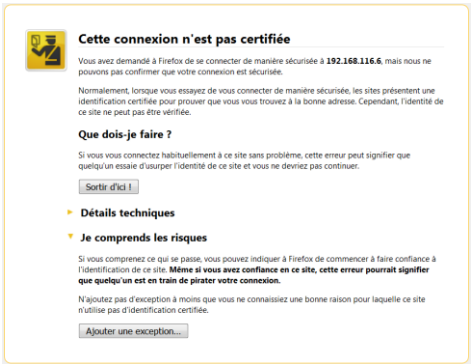
3. certificat à validation de domaine (DV) : niveau de chiffrement le plus bas
Le certificat DV confirme simplement que vous êtes le propriétaire du site web et que vous en administrez activement les pages. Ce que le certificat DV ne confirme pas, c'est que celui-ci a été spécifiquement émis pour votre entreprise ou que votre site est effectivement exploité par votre entreprise.

Chapitre 1

Qu'est-ce qu'un certificat auto-signé alors ?

Un certificat auto-signé est un certificat gratuit créé à partir d'une boite à outils open source (comme OpenSSL). OpenSSL vous permet en effet de créer en quelques étapes votre certificat SSL, à condition de maîtriser Linux.

Un certificat SSL auto-signé peut déclencher un message d'alerte dans les navigateurs web alors qu'un certificat SSL *(de type X.509)* émit par une autorité de certification vous assure le *cadenas vert* pour l'intégralité de votre domaine.



Chapitre 1

La création d'un certificat auto-signé convient pour une utilisation personnelle, à contrario, pour sécuriser votre site internet, votre certificat SSL doit être délivré par une *Autorité de Certification (AC)*.

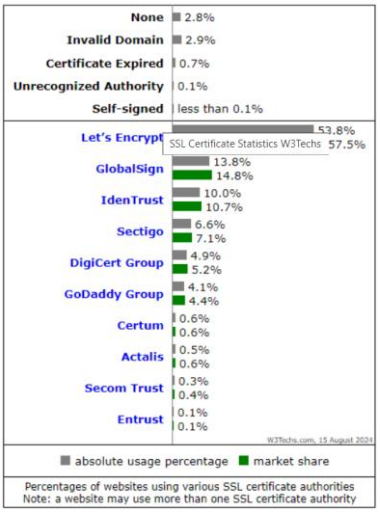
A savoir : L'autorité de certification « ***Let's Encrypt*** », créé par le groupe de recherche sur la sécurité Internet *(ISRG),* une autorité de certification qui délivre des certificats SSL gratuits (de type DV).
L'autorité de certification « *StartSSL* » délivre également des certificats SSL gratuits.



Chapitre 1

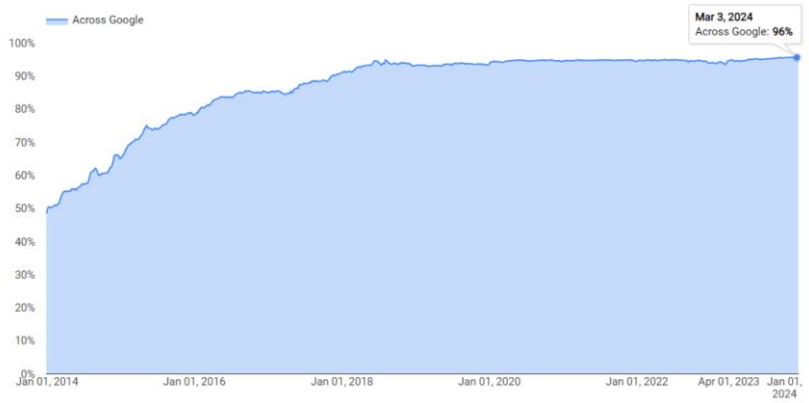
90% de tous les certificats utilisés proviennent de seulement 6 autorité de certifications.

Les **certificats à validation de domaine** représentent **94,4%** des certificats utilisés alors que les **certificats à validation d'organisation** sont utilisés dans **5,5%** des cas et les **certificats à validation étendue** représentent à peine ***0.1%*** de parts de marché...



*Source: **W3Techs.com** et **Netcraft.com***

Selon un rapport datant de mai 2024, + de 96% des pages Web chargées dans Chrome utilisent HTTPS. Ce qui est une belle évolution sur la dernière décennie !

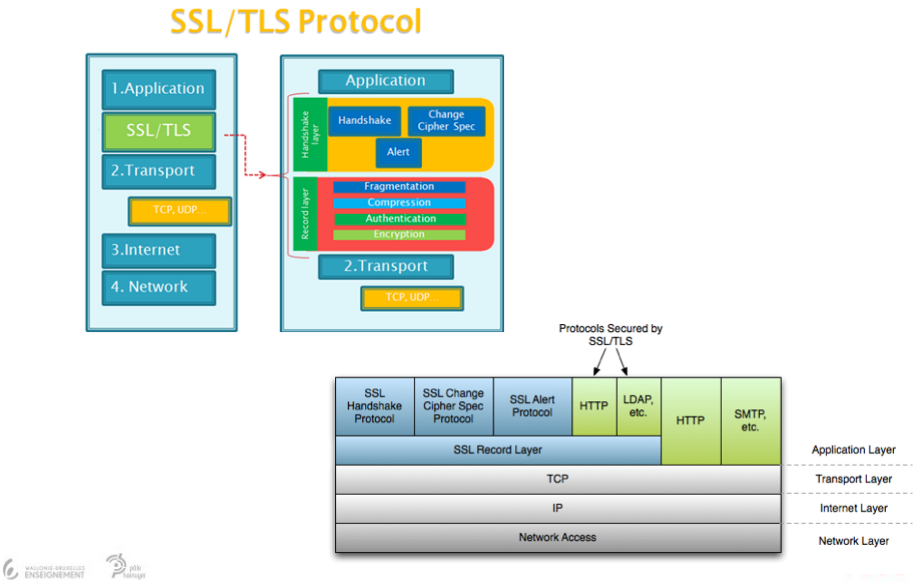


A quel niveau du modèle OSI ou TCP/IP intervient ce protocole SSL (ou TLS) ?

Dans la pile de protocole TCP/IP, SSL se situe entre la couche application (où se trouvent des protocoles comme HTTP, FTP, SMTP,...) et la couche transport.

Son utilisation la plus commune reste cependant en dessous de HTTP. Le protocole SSL est implémenté au niveau de la couche session de la pile (selon le modèle OSI), ce qui a deux conséquences :

- pour toute application existante utilisant TCP, il peut exister une application utilisant SSL. Par exemple, l'application HTTPS correspond à HTTP au-dessus de SSL.
- une application SSL se voit attribuer un nouveau numéro de port par l'IANA. Par exemple HTTPS est associé au port 443. Dans certains cas, le même port est utilisé avec et sans SSL. Dans ce cas, la connexion est initiée en mode non chiffré. Le tunnel est ensuite mis en place au moyen d'un protocole « *StartTLS* ». C'est le cas, par exemple, des protocoles IMAP, SMTP ou LDAP.



Evolution de SSL/TLS :

SSL est initialement apparu en 1995 dans le navigateur internet Netscape. Depuis, ce protocole de sécurité a bien évolué et il existe de nos jours (en 2018) 6 versions :

- SSLv2, première version réellement utilisée (SSLv1 n'était que théorique) mais à éviter à l'heure actuelle.

- SSLv3, apparu en 1996, il est également à éviter à l'heure actuelle.

- TLSv1.0, développé en 1999 par l'IETF pour succéder au protocole SSL. Il est encore utilisé mais son utilisation commence à décroître (au profit de versions plus récentes) !

- TLSv1.1, datant de 2006, qui est une version de transition.

- TLSv1.2, sortie en 2008, apporte une évolution importante qui est l'Authenticated Encryption with Associated Data (**AEAD**). L'AEAD est une forme de chiffrement qui fournit simultanément une assurance de confidentialité, d'intégrité et d'authenticité des données.

Malheureusement TLS 1.2 autorise l'usage de vieilles suites cryptographiques ce qui permet de réaliser des mélanges de modernité et d'archaïsme potentiellement dangereux.

- TLSv1.3, la dernière version TLS, sortie cette année (2018). Les principales évolutions sont l'abandon du support des algorithmes trop faibles (MD4, RC4, DSA ou SHA-224), une négociation en moins d'étapes (qui est donc plus rapide par rapport à TLS 1.2)

Remarque :
SSL et TLS ne sont pas directement interopérables.
Cependant TLS, comme SSLv3, intègre un mécanisme de compatibilité ascendante avec les versions précédentes, c'est-à-dire qu'au début de la phase de négociation, le client et le serveur négocient la « meilleure » version du protocole disponible par tous deux.

Pour en savoir plus au sujet de SSL et TLS, je vous conseille d'aller lire ceci :
https://openweb.eu.org/articles/https-de-ssl-a-tls-1-3

HEH be Sciences et technologies

Chapitre 1

Certificat et signature numérique

Rappel : une signature numérique vérifie l'identité de l'expéditeur et l'intégrité du message, grâce à sa clé publique.

Mais comment être sûr que cette clé publique appartient bien à la bonne personne ? C'est le rôle du **certificat numérique**.

Le certificat, délivré par une **Autorité de Certification** de confiance, associe une identité à une clé publique donnée.

Avant de vérifier une signature, on vérifie donc d'abord le certificat associé à la clé publique de l'expéditeur.

C'est le même principe pour un site web en HTTPS : son certificat SSL/TLS garantit qu'il communique bien avec le bon site.